

KALI LINUX

IA, pruebas de seguridad y forense digital

*Manual práctico para principiantes y para la comprensión
Cuándo, por qué y cómo usar herramientas esenciales*

Preparado por Alberto (AI) Leiva

Final Español Edición v1.0 - julio 2026

Revisado para Kali Linux 2026.2 Edición

Maestra en inglés

RECURSO EDUCATIVO GRATUITO

Un guía independiente. No patrocinado, respaldado ni afiliado oficialmente a Kali Linux, OffSec o Hack The Box.

Prefacio

Transmitiendo conocimiento hacia adelante

Creé este manual porque quería que los principiantes tuvieran el tipo de guía que habría valorado cuando entré en el campo de la tecnología y la ciberseguridad. Las herramientas poderosas son más fáciles de encontrar que las explicaciones pacientes. Mi objetivo es explicar no solo qué hace una herramienta, sino también por qué importa, cuándo debe usarse y qué responsabilidades conlleva su uso.

Después de muchos años en la industria, creo que la experiencia tiene el mayor valor cuando se comparte. La tecnología cambia constantemente, pero la necesidad de curiosidad, disciplina, ética y buen juicio no. Este libro es mi manera de transmitir esas lecciones a estudiantes, personas que cambian de carrera y jóvenes que algún día puedan proteger los sistemas e información de los que dependemos el resto de nosotros.

También entiendo que aprender no es lo mismo para todos. Tengo disgrafía, una dificultad de aprendizaje que puede afectar la escritura, la ortografía y la organización de la información escrita. Las ideas y la experiencia eran mías, pero convertirlas en un libro claro y estructurado habría sido extremadamente difícil para mí sin el apoyo de un asistente de redacción y edición con IA.

Esa ayuda no sustituyó la experiencia profesional, el juicio ni la responsabilidad. Me ayudó a organizar mis ideas, mejorar el lenguaje, verificar la coherencia y presentar el material de forma que otras personas puedan usarlo. Cada tecnología debe abordarse de la misma manera: como una herramienta que puede ampliar la capacidad humana cuando se usa con cuidado, honestidad y responsabilidad.

Este manual se ofrece gratuitamente porque la oportunidad no debería depender únicamente de los ingresos, la ubicación, el idioma o las diferencias de aprendizaje de una persona. Espero que esto le dé a alguien la confianza para empezar, la paciencia para seguir aprendiendo y un interés de por vida en el mundo cambiante y desafiante de la ciberseguridad, la inteligencia artificial y la informática forense.

Sobre todo, espero que los lectores recuerden que la habilidad técnica es solo una parte de convertirse en un profesional de la seguridad. El carácter, el permiso, el respeto hacia los demás y la disposición a usar el conocimiento para el bien son igualmente importantes.

— *Alberto (AI) Leiva*

Sobre este manual

Este manual fue creado para ayudar a los principiantes a dar sus primeros pasos en Kali Linux, en herramientas de inteligencia artificial, en hacking ético, en pruebas de seguridad y en forense digital. No necesitas ser un experto para empezar. Necesitas curiosidad, paciencia y disposición para aprender con responsabilidad.

La ciberseguridad está en constante cambio. Aparecen nuevas tecnologías, se descubren nuevas vulnerabilidades y se desarrollan nuevas defensas cada día. Eso es parte de lo que hace que este campo sea un reto, y también lo hace emocionante. El propósito de este manual gratuito no es simplemente enseñar órdenes. Es para ayudar a los lectores a entender por qué se utiliza una herramienta, cuándo debe usarse, qué significan los resultados y qué responsabilidades conlleva la habilidad técnica.

La regla que guía cada capítulo

La habilidad técnica no otorga permiso. El hacking ético requiere autorización clara, un alcance definido, cuidado de la información de otras personas y honestidad en la información.

Licencia

A menos que una sección indique lo contrario, el texto original de este manual se comparte bajo la licencia Creative Commons.

Atribución-No Comercial-Compartir Igual 4.0 Internacional (CC BY-NC-SA 4.0). Puedes compartir y adaptar el material para fines no comerciales, siempre que proporciones la atribución y distribuyas las adaptaciones bajo la misma licencia. Los nombres de terceros, marcas registradas, capturas de pantalla, documentación y código siguen siendo propiedad de sus respectivos titulares. [Creative Commons CC BY-NC-SA 4.0](https://creativecommons.org/licenses/by-nc-sa/4.0/)

Aviso importante

Esta publicación es educativa y no constituye asesoramiento legal. Las leyes varían según el país y las circunstancias. Realiza ejercicios únicamente en laboratorios autorizados o en sistemas que poseas y controles. El autor y los colaboradores no autorizan ni fomentan accesos no autorizados, interrupciones, robo de credenciales, violaciones de la privacidad ni otras actividades dañinas.

Cómo usar esta primera edición

- Lee los capítulos sobre ética y seguridad en el laboratorio antes de usar herramientas de seguridad.
- Empieza con una máquina virtual a menos que tengas una razón sólida para instalar Kali directamente en el hardware.
- Usa Hack The Box Starting Point o tu propio laboratorio intencionalmente vulnerable para practicar.
- Escribe los comandos tú mismo y entiende el objetivo antes de pulsar Enter.
- Toma notas. Cada capítulo práctico incluye una mentalidad de interpretación e informe.
- Consulta la documentación oficial, ya que Kali y sus herramientas cambian con frecuencia.

Índice y índice

Prefacio.....	2
Transmitiendo conocimiento hacia adelante	2
Sobre este manual.....	2
Licencia	3
Aviso importante	3
Cómo usar esta primera edición.....	3
Índice y índice.....	3
1. Fundamentos, carreras y habilidades profesionales de la seguridad en IA.....	7
1.1 Fundamentos de seguridad en IA y habilidades profesionales	7
1.2 Semgrep para código de aplicación segura de IA	7
1.3 Continuar con el desarrollo asistido por IA.....	8
1.4 Cara de abrazo	8
1.5 Un flujo de trabajo de red-team para IA para principiantes.....	8
2. Hoja de ruta de aprendizaje, ética y práctica responsable	9
2.1 Cómo usar este manual y hoja de ruta de aprendizaje	9

2.2 Hacking ético, autorización y consecuencias.....	9
3. Elegir e instalar Kali Linux	11
3.1 ¿Qué imagen debería elegir un principiante?	11
3.2 Hardware recomendado.....	12
3.3 VMware en Windows - recomendado para muchos principiantes	12
3.4 Lista de verificación práctica.....	12
3.5 Hyper-V en Windows 11 Pro.....	12
3.6 Lista de verificación práctica.....	13
3.7 VirtualBox	13
3.8 Lista de verificación práctica.....	13
3.9 Partición separada y arranque dual.....	13
3.10 Lista de verificación práctica.....	13
3.11 Ordenadores Mac.....	14
3.12 Lista de verificación práctica.....	14
3.13 Primer arranque, actualizaciones y valores predeterminados de seguridad	14
3.14 Comandos esenciales de Linux	14
3.15 Recorridos detallados de la instalación	15
3.16 Antes de descargar nada	15
3.17 Elige la imagen correcta de Kali	15
3.18 VMware Workstation en Windows: la opción más fácil para muchos principiantes.....	15
3.19 Hyper-V en Windows 11 Pro, Enterprise o Education	16
3.20 Oracle VirtualBox en Windows, Linux o Mac Intel.....	17
3.21 Kali en Apple Silicon Mac - M1, M2, M3 y versiones posteriores.....	17
3.22 Mac basado en Intel	18
3.23 Partición separada o arranque dual con Windows.....	18
3.24 Instalación de ordenadores dedicados.....	19
3.25 Primera lista de comprobación de arranque para cada instalación	19
3.26 Enlaces de virtualización en un vistazo.....	19
4. Construir un laboratorio de prácticas seguras.....	20
4.1 Hack The Box como área principal de práctica	20
4.2 Flujo de trabajo seguro de HTB	20
5. Herramientas de IA para el aprendizaje en ciberseguridad.....	21
5.1 Ollama.....	21
5.2 Open WebUI	22
5.3 Promptfoo.....	23
5.4 Giskard	23
5.5 LangChain	24

5.6 LlamaIndex.....	25
5.7 Ayuda.....	26
5.8 Intérprete abierto.....	27
6. MCP, RAG y agentes de IA.....	28
6.1 RAG en lenguaje claro.....	28
6.2 Bases de datos vectoriales en lenguaje sencillo.....	28
6.3 Agentes y uso de herramientas.....	28
6.4 Protocolo de Contexto de Modelo (MCP): un principio fundamental de seguridad en IA.....	28
6.5 Por qué el MCP es importante para los empleadores.....	28
6.6 Los principios de seguridad detrás de MCP.....	28
6.7 Una lista de comprobación para principiantes de reseñas de MCP.....	29
6.8 Agentes de IA: la idea básica.....	29
6.9 Los riesgos que todo empleador debería comprender.....	29
6.10 Microsoft Azure y Microsoft Foundry: fundamentos de la seguridad.....	29
6.11 AWS y Amazon Bedrock: fundamentos de seguridad.....	29
6.12 API OpenAI y flujos de trabajo conectados a ChatGPT: fundamentos de la seguridad.....	30
6.13 Una lista mínima de comprobación para empleadores de agentes de IA.....	30
6.14 Referencias oficiales de inicio.....	30
6.15 Una lista de verificación sencilla de seguridad para IA.....	31
7. GRC y Gobernanza de la IA.....	32
7.1 Gobernanza.....	32
7.2 Riesgo.....	32
7.3 Cumplimiento.....	32
7.4 Documentos importantes para principiantes.....	32
7.5 Preguntas sobre la gobernanza de la IA.....	32
7.6 Marcos a reconocer.....	32
8. Herramientas esenciales de seguridad de Kali.....	34
8.1 Elegir la herramienta Kali adecuada.....	34
8.2 Veinte herramientas esenciales de seguridad Kali.....	34
8.3 Nmap.....	34
8.4 Wireshark.....	35
8.5 Edición Comunitaria de Burp Suite.....	36
8.6 Marco Metasploit.....	36
8.7 Gobuster.....	37
8.8 FFUF.....	38
8.9 Nadie.....	39
8.10 sqlmap.....	40

8.11 OWASP ZAP	40
8.12 Hydra	41
8.13 Juan el Destripador	42
8.14 Hashcat	43
8.15 Aircrack-ng	43
8.16 Bettercap	44
8.17 Respuesta	45
8.18 NetExec	46
8.19 enum4linux-ng	46
8.20 Searchsploit	47
8.21 Autopsia	48
8.22 Maltés	49
9. Fundamentos y herramientas de la Forense Digital	50
9.1 Fundamentos de la Forense Digital	50
9.2 Kit de Detective	50
9.3 Guymager	51
9.4 ExifTool	52
9.5 Pasarela de contenedores	53
9.6 Volatilidad 3	54
9.7 Primero	54
9.8 bulk_extractor	55
9.9 Plaso/log2timeline	56
9.10 HIJOS	57
9.11 Ghidra	58
10. Informando de lo que aprendes	59
10.1 Plantilla sencilla de encontrar	59
10.2 Evita estos errores de reporte	59
11. Tus primeros 30 días con Kali Linux	59
11.1 Semana 1 - Construir cimientos seguros	59
11.2 Semana 2 - Aprende a observar	60
11.3 Semana 3 - Inicio de la práctica web y HTB	60
11.4 Semana 4 - Conecta las habilidades	60
12. Inglés para carreras tecnológicas	60
12.1 Donde aparece el inglés	60
12.2 Un objetivo realista	60
12.3 Recursos gratuitos para aprender inglés disponibles en todo el mundo	61
12.4 Un sencillo plan semanal de inglés	61

13. Trayectoria profesional y aprendizaje continuo.....	61
Patrón de carpeta de laboratorio	62
Estructura planificada del repositorio de GitHub.....	65

1. Fundamentos, carreras y habilidades profesionales de la seguridad en IA

1.1 Fundamentos de seguridad en IA y habilidades profesionales

La seguridad de la IA es mucho más que usar un chatbot. Combina seguridad de software, protección de datos, pruebas de modelos, gobernanza, privacidad y comunicación clara. Esta sección muestra dónde se están desarrollando los trabajos y qué puede aprender primero un principiante.

Por qué la seguridad en IA es un área profesional en crecimiento

Las organizaciones están integrando IA generativa, copilotos, sistemas de recuperación y agentes automatizados en sus procesos empresariales. Estos sistemas generan nuevas preguntas: ¿Qué datos puede ver el modelo? ¿Puede un usuario manipular sus instrucciones? ¿Puede el modelo llamar a herramientas que no debería usar? ¿Puede aparecer información sensible en una respuesta? Los profesionales de la seguridad de la IA ayudan a responder a esas preguntas antes de que un sistema cause daños.

1. Analista de seguridad en IA: revisa riesgos, prueba las salvaguardas y documenta los hallazgos.
2. Analista de gobernanza de IA: ayuda a crear políticas, inventarios, aprobaciones y pruebas.
3. Tester de seguridad de LLM o tester de equipo rojo de IA: evalúa la inyección rápida, la fuga de datos, el uso inseguro de herramientas y otros modos de fallo.
4. Ingeniero de IA seguro: añade autenticación, autorización, filtrado, registro y monitorización a aplicaciones de IA.
5. Especialista en seguridad RAG: protege la recuperación de documentos, bases de datos vectoriales, permisos de fuente y citas.
6. Especialista en riesgos y cumplimiento en IA: conecta los controles técnicos con NIST, ISO, la privacidad y los requisitos contractuales.
7. Analista de respuesta a incidentes de IA: investiga el mal uso, la filtración de datos, los resultados perjudiciales y los flujos de trabajo comprometidos de la IA.

Un principiante no necesita dominar todos los roles. Empieza con Linux, redes, lo básico de Python, pruebas seguras y la capacidad de explicar un hallazgo con claridad.

1.2 Semgrep para código de aplicación seguro de IA

Qué es y por qué usarlo

Semgrep es una herramienta de escaneo de código fuente. Busca patrones en el código que puedan indicar errores de seguridad, como secretos codificados de forma dura, manejo inseguro de entradas o uso inseguro de la API. Es valioso para aplicaciones de IA porque muchos fallos de IA provienen del código circundante y no del propio modelo.

Cuándo usarlo

Revisando tu propio proyecto de IA en Python o en JavaScript.

Comprobar si las claves de API se incluyeron accidentalmente en el código fuente.

Identificar funciones arriesgadas antes de una revisión de código.

Instalar y comprobar

Utiliza un entorno virtual de Python siempre que sea posible. Luego instala Semgrep con pip y confirma que empieza con semgrep --version. Kali también puede proporcionar una versión empaquetada, pero la documentación oficial debe consultarse para conocer el método vigente.

Primer ejercicio seguro

1. Crea un pequeño archivo de práctica que contenga una contraseña falsa para el examen.
2. Ejecuta Semgrep solo contra esa carpeta local de prácticas.
3. Lee el nombre de la regla y la ubicación del archivo.
4. Elimina la contraseña falsa y vuelve a realizar el escaneo.
5. Escribe una frase que explique por qué los secretos deberían almacenarse fuera del código fuente.

[Documentación oficial de Semgrep](#)

1.3 Continuar con el desarrollo asistido por IA

Continue es un asistente de programación de IA que puede trabajar en entornos de desarrollo compatibles. Puede explicar el código, sugerir cambios y conectarse a modelos locales o alojados. Úsalo como ayudante, no como autoridad. Cada cambio sugerido debe ser revisado y comprobado.

Reglas de seguridad para principiantes

- ✓ Usa un repositorio de prácticas, no un sistema de producción.
- ✓ No envíes código de cliente privado a un modelo público sin aprobación previa.
- ✓ Revisa los archivos y comandos exactos que propone el asistente.
- ✓ Usa Git para que los cambios no deseados puedan revertirse. [Documentación oficial de Continue](#)

1.4 Cara de abrazo

Hugging Face es un gran ecosistema de modelos, conjuntos de datos, demostraciones y bibliotecas de desarrollo. Ayuda a los alumnos a entender que los modelos tienen licencias, usos previstos, limitaciones, tamaños de archivo y consideraciones de seguridad. Debe leerse una página del modelo antes de descargarlo o usarlo.

Lo que debería comprobar un principiante

- ✓ La licencia del modelo y los usos permitidos.
- ✓ La tarjeta del modelo y las limitaciones conocidas.
- ✓ Si el código debe ser confiable o ejecutarse.
- ✓ El tamaño de la descarga y los requisitos de hardware.
- ✓ Si el repositorio es mantenido por una organización reconocida o por una cuenta desconocida. [Documentación de Abrazo en la cara](#)

1.5 Un flujo de trabajo de red-team para IA para principiantes

El red teaming de IA consiste en probar un sistema de IA para detectar comportamientos dañinos o inesperados, con permiso. No es una excusa para atacar un chatbot público ni para eludir los controles de otra organización.

1. Anota la aplicación autorizada, los usuarios, los datos, el modelo y el periodo de prueba.
2. Enumera los comportamientos que deben protegerse, como los datos confidenciales, las instrucciones del sistema y los permisos de las herramientas.
3. Crea primero indicaciones estándar para que entiendas el comportamiento esperado.
4. Prueba una categoría de riesgo a la vez, como la inyección rápida o el uso inseguro de herramientas.
5. Guarda el prompt, la respuesta, la versión del modelo, la configuración y la hora.
6. Repite la prueba para determinar si el comportamiento es consistente.
7. Explica el impacto sin exagerar.
8. Recomienda un control y una nueva prueba tras aplicarlo.

2. Hoja de ruta de aprendizaje, ética y práctica responsable

2.1 Cómo usar este manual y hoja de ruta de aprendizaje

Sección	Lo que aprenderás
Parte I	Ética, consecuencias y mentalidad profesional
Parte II	Elegir, instalar y mantener Kali Linux
Parte III	Construir un laboratorio de práctica segura y usar Hack The Box
Parte IV	Herramientas de IA para el aprendizaje, la prueba y el análisis
Parte V	Veinte herramientas esenciales de seguridad de Kali
Parte VI	Fundamentos y herramientas de la informática forense digital
Parte VII	Reportajes, trayectorias profesionales y tus primeros 30 días
Apéndices	Listas de comprobación, glosario, enlaces oficiales y notas de fuentes

Orden de aprendizaje sugerido

1. Lee las Partes I-III antes de ejecutar las herramientas.
2. Instala Kali en una máquina virtual y crea una instantánea limpia.
3. Aprende navegación y redes básicas en Linux.
4. Usa la sección de IA para ayudar a entender, no para reemplazarla.
5. Practica el reconocimiento y el análisis de tráfico antes de explotar.
6. Completa la sección de forense usando pruebas de ejemplo, nunca pruebas originales.
7. Escribe un informe breve después de cada laboratorio.

2.2 Hacking ético, autorización y consecuencias

El hacking ético es el uso legal de técnicas de seguridad para identificar debilidades y fortalecer las defensas. La misma orden puede ser ética en un laboratorio e ilegal en un sistema no aprobado. La diferencia está en el permiso, el alcance, el propósito y la conducta.

El permiso es específico, no se asume

El permiso debe identificar los sistemas, las fechas, las técnicas permitidas, los contactos y las condiciones de detención. El permiso para usar un sitio web no implica permiso para probarlo. El empleo en una organización no implica automáticamente permiso para escanear su red. Un amigo que diga "prueba mi Wi-Fi" puede no bastar si el router, el servicio o los datos pertenecen a otra persona.

El alcance evita que las buenas intenciones causen daño

El alcance define los límites de una prueba. Puede incluir direcciones IP específicas, aplicaciones, cuentas, horarios y acciones prohibidas. Si un resultado apunta a un sistema fuera del alcance, detente y pregunta. No sigas el sendero simplemente porque, técnicamente, sea posible.

Consecuencias de un comportamiento no autorizado

La actividad de seguridad no autorizada puede causar la suspensión de cuentas, sanciones escolares, pérdida de empleo, reclamaciones civiles, investigaciones penales, daños económicos, pérdida de certificaciones y daños reputacionales a largo plazo. También puede perjudicar a personas inocentes al exponer mensajes privados, historiales médicos, fotografías, datos financieros o operaciones empresariales.

Comportamiento responsable cuando descubres un problema

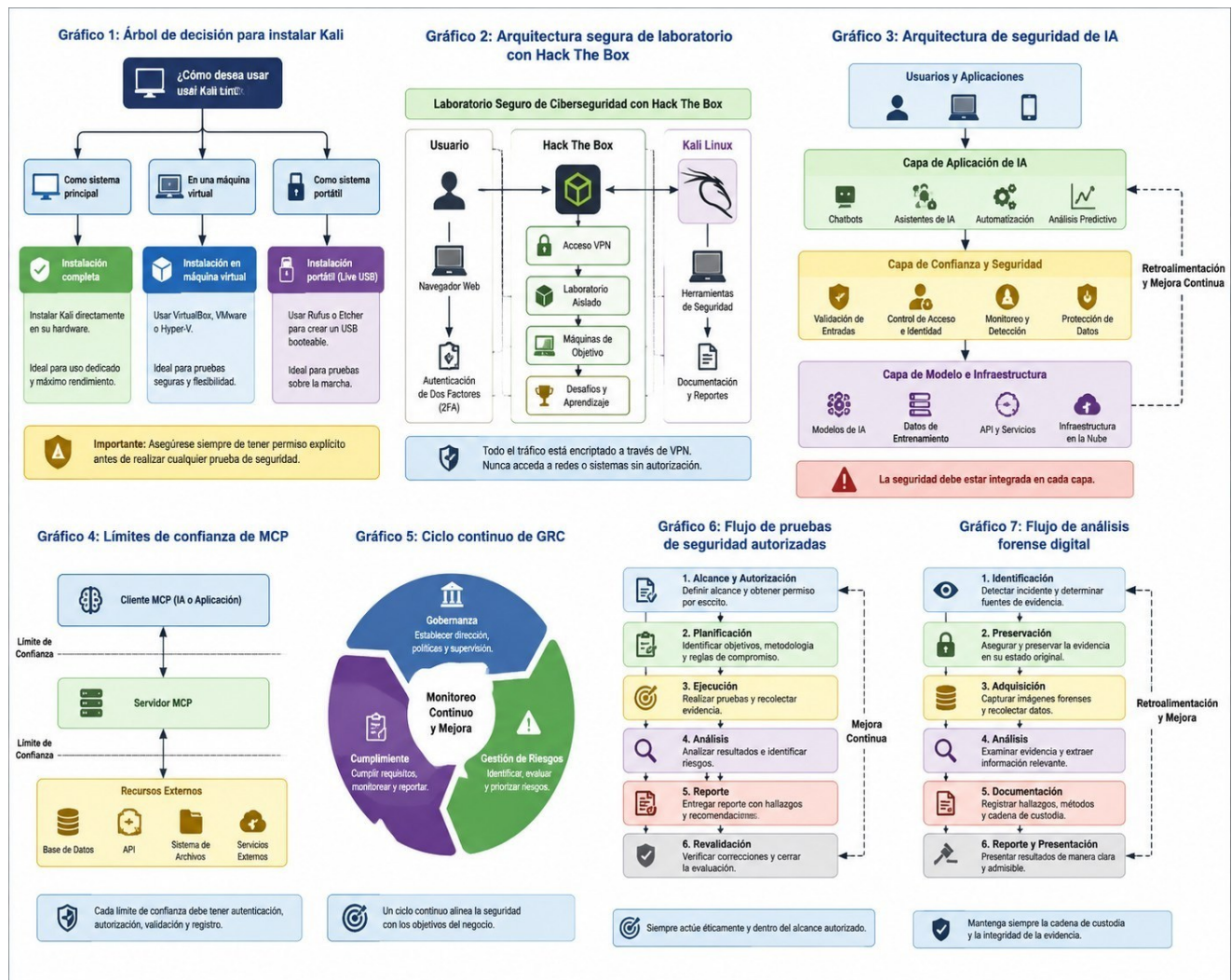
No descargues más información de la necesaria para demostrar el problema. No identifique públicamente a las personas afectadas. Registrar la evidencia mínima necesaria, protegerla y reportarla a través del canal de seguridad publicado por la organización o mediante un proceso de divulgación responsable adecuado.

Condiciones de parada

Para inmediatamente si accedes a datos personales, obtienes acceso administrativo inesperado, causas inestabilidad, identificas al objetivo equivocado, pierdes la autorización o no estás seguro de si la siguiente acción está permitida.

Escenarios de práctica

Escenario	Respuesta profesional
Un estudiante escanea la red del colegio para "ver qué hay disponible".	No es ético sin autorización explícita. La curiosidad no sustituye el permiso.
Un alumno escanea una máquina de Hack The Box asignada a su cuenta.	Es apropiado cuando la acción sigue las normas del laboratorio y se mantiene dentro del objetivo asignado.
Un amigo comparte una contraseña de Wi-Fi y solicita una comprobación de seguridad.	Pausa. Aclarar la propiedad, el permiso escrito, las acciones permitidas y si otros usuarios o equipos del proveedor pueden verse afectados.
Un investigador encuentra una página pública de inicio de sesión y prueba contraseñas comunes.	Pruebas de credenciales no autorizadas. El acceso público no permite ataques mediante contraseña.
Un alumno analiza una imagen descargable de la práctica forense.	Es apropiado cuando la evidencia se proporciona para el entrenamiento y se maneja según las instrucciones del ejercicio.



3. Elegir e instalar Kali Linux

Elegir e instalar Kali Linux

Kali Linux es una distribución Linux especializada para pruebas de penetración, evaluación de seguridad, forense digital y trabajos relacionados. Contiene muchas herramientas potentes, pero sigue siendo un sistema operativo Linux. Los principiantes deben aprender primero a instalar de forma segura actualizaciones, archivos, usuarios, permisos, redes y la recuperación.

Nota de versión actual

Esta primera edición fue revisada en comparación con la versión oficial de Kali Linux 2026.2 disponible en julio de 2026. Kali está en marcha y sus imágenes oficiales de lanzamiento puntual se actualizan trimestralmente. Verifica siempre la versión actual en la página oficial de descarga.

[Descargas oficiales de Kali para Linux](#)

[Documentación oficial de Kali Linux](#)

3.1 ¿Qué imagen debería elegir un principiante?

- ✓ Ordenador con Windows o Linux y procesador Intel/AMD: utiliza la imagen oficial de lanzamiento puntual x86_64/AMD64.
- ✓ Mac Apple Silicon: utiliza una imagen ARM64 diseñada para la virtualización de Apple Silicon.
- ✓ VMware, VirtualBox o Hyper-V: prefieren una imagen oficial de máquina virtual preconstruida cuando esté disponible.

- ✓ Instalación directa o arranque dual: usa la imagen oficial del instalador, no un ISO reempaquetado no oficial.
- ✓ Evita las imágenes semanales como primera opción, a menos que necesites específicamente una solución reciente y entiendas que estas reciben menos pruebas de liberación puntuales.

3.2 Hardware recomendado

Los diagramas de este manual son instructivos. Cada uno resume el texto circundante para que un principiante pueda ver la relación entre elecciones, sistemas y controles de seguridad antes de leer los detalles.

Figura 1. Una guía para principiantes sobre cómo elegir un método de instalación de Kali.

Uso	Punto de partida razonable	Recomendación cómoda
Uso	Punto de partida razonable	Recomendación cómoda
Basic Kali VM	2 núcleos de CPU, 4 GB de RAM, disco de 60 GB	4 núcleos de CPU, 8 GB de RAM, 80-100 GB de disco
Kali más IA local	4 núcleos de CPU, 8-12 GB de RAM, disco de 100 GB	6-8 núcleos de CPU, 16 GB de RAM, 150 GB de disco
Práctica forense	4 núcleos de CPU, 8 GB de RAM, 120 GB de disco	6 núcleos de CPU, 16 GB de RAM, almacenamiento de pruebas separado

Camino de pocos recursos

Un aprendiz con hardware limitado puede usar una máquina virtual Kali más pequeña para herramientas básicas y usar Hack The Box Pwnbox para acceso a laboratorios por navegador. Los modelos de lenguaje grandes locales pueden ser poco prácticos en máquinas antiguas; Las herramientas de IA en la nube pueden utilizarse con precauciones de privacidad.

3.3 VMware en Windows - recomendado para muchos principiantes

VMware ofrece una integración sólida en el escritorio, instantáneas y un manejo sencillo de dispositivos USB.

Descarga la imagen oficial preconstruida de Kali para VMware cuando sea posible.

Confirma que la virtualización está habilitada en el firmware del ordenador. Instala VMware Workstation, descarga el archivo oficial de Kali para VMware, verifica la descarga, sácalo, abre la máquina virtual y cambia la contraseña por defecto.

Empieza por la red NAT. NAT permite a Kali acceder a Internet a través del host mientras reduce la exposición accidental a la red local. Usa el modo puente solo cuando el laboratorio lo requiera y entiendas el efecto.

3.4 Lista de verificación práctica

- ✓ Crea una instantánea llamada "Clean Install" antes de añadir herramientas.
- ✓ No almacenes archivos ni secretos de VPN en una carpeta pública compartida.
- ✓ Utiliza solo redes de host para laboratorios aislados con múltiples VMs.

Recomendación para principiantes

Usa una máquina virtual, crea una instantánea limpia y practica allí antes de plantearte una instalación directa.

3.5 Hyper-V en Windows 11 Pro

Kali ahora proporciona una imagen oficial preconstruida de Hyper-V. Extrae el archivo oficial y ejecuta su script de instalación con aprobación administrativa, o crea una VM de Generación 2 a partir del ISO del instalador.

El Modo de Sesión Mejorado de Hyper-V puede ofrecer funciones de portapapeles e intercambio de archivos. El paso por USB es menos directo que en algunos hipervisores de escritorio, lo cual es importante para adaptadores inalámbricos y ciertos dispositivos forenses.

3.6 Lista de verificación práctica

1. Usa la imagen oficial preconstruida de Hyper-V para la configuración más sencilla.
2. Mantén el disco virtual en un lugar con suficiente espacio libre.
3. Crea un punto de control después de la primera actualización.

Recomendación para principiantes

Usa una máquina virtual, crea una instantánea limpia y practica allí antes de plantearte una instalación directa.

3.7 VirtualBox

VirtualBox está ampliamente disponible y funciona bien para laboratorios de práctica aislados. Kali proporciona tanto orientación de instalación como imágenes precompiladas de VirtualBox.

Importa el dispositivo oficial o crea una máquina virtual con el instalador. Instala las adiciones de invitados si es necesario y toma instantáneas antes de realizar cambios importantes en la herramienta o en la configuración.

3.8 Lista de verificación práctica

Para un trabajo de laboratorio más seguro, desactiva la carpeta compartida y las carpetas compartidas al manipular muestras no confiables. Usa NAT para el aprendizaje normal y redes de host solo para laboratorios locales aislados.

Recomendación para principiantes

Usa una máquina virtual, crea una instantánea limpia y practica allí antes de plantearte una instalación directa.

3.9 Partición separada y arranque dual

El arranque dual proporciona acceso directo al hardware y mejor rendimiento, pero es más arriesgado para principiantes porque los errores de particionado y de arranque pueden dejar el sistema operativo existente inaccesible.

Haz una copia de seguridad de los archivos importantes, guarda la clave de recuperación de BitLocker, desactiva el Inicio Rápido, reduce la partición de Windows en la Gestión de Discos de Windows y deja el nuevo espacio sin asignar. Arranca el instalador oficial de Kali en modo UEFI, igual que en Windows.

Nunca selecciones la opción de disco completo si tienes la intención de conservar el sistema operativo existente. Lee cada pantalla de partición despacio.

3.10 Lista de verificación práctica

- ✓ Usa primero una máquina virtual a menos que realmente se requiera acceso directo al hardware.
- ✓ Mantén disponibles los medios de recuperación.
- ✓ No reparticiones un ordenador que contenga datos insustituibles sin una copia de seguridad probada.

Recomendación para principiantes

Usa una máquina virtual, crea una instantánea limpia y practica allí antes de plantearte una instalación directa.

3.11 Ordenadores Mac

No existe una "edición para Mac" separada de Kali. Los Mac Intel usan imágenes de 64 bits (x64), mientras que los Mac Apple Silicon requieren imágenes de 64 bits ARM (ARM64).

En Apple Silicon, VMware Fusion, Parallels y UTM son opciones habituales. Muchas herramientas funcionan normalmente, pero algunos paquetes, controladores y flujos de trabajo de hardware solo para x86 pueden variar. La instalación directa en hardware de Mac puede variar según el modelo. Una máquina virtual es el punto de partida más seguro para la mayoría de los aprendices.

3.12 Lista de verificación práctica

1. Verifica si el Mac es de Intel o de Apple Silicon antes de descargarlo.
2. Usa una imagen de Kali ARM64 en Macs de la serie M.
3. Se espera que los adaptadores Wi-Fi externos requieran hardware compatible y acceso USB a VM.

Recomendación para principiantes

Usa una máquina virtual, crea una instantánea limpia y practica allí antes de plantearte una instalación directa.

3.13 Primer arranque, actualizaciones y valores predeterminados de seguridad

1. Cambia cualquier contraseña predeterminada o temporal.
2. Confirma la fecha, la zona horaria, la distribución del teclado y la conexión a la red.
3. Actualiza la información del paquete y aplica las mejoras habituales.
4. Reinicia cuando se actualicen el núcleo o los componentes centrales del sistema.
5. Crea una instantánea limpia una vez que el sistema esté estable.
6. Crea una carpeta dedicada a cada laboratorio y mantén las notas separadas de la salida de la herramienta.

```
sudo apt update;
sudo apt full-upgrade -y;
sudo reboot
```

¿Por qué una actualización completa?

Kali es una distribución continua. La documentación oficial suele recomendar una actualización completa para que las relaciones de paquetes puedan gestionarse correctamente. Revisa las propuestas de eliminación antes de aceptar cambios inesperados.

3.14 Comandos esenciales de Linux

Mando	Propósito
PWD	Muestra el directorio actual.
ls -la	Archivos de lista, incluyendo archivos ocultos.
Carpeta de CD	Muévelo a una carpeta.
Nombre del laboratorio mkdir	Crea un directorio.
CP / MV	Copiar o mover archivos.
Gato / Menos	Lee la salida del texto.
Agarre	Buscar texto.
IP addr	Consulta las interfaces y direcciones de red.
SS -TULPN	Ver los enchufes de red de escucha.
Herramienta de hombre	Abre una página de manual.

3.15 Recorridos detallados de la instalación

Esta sección explica cada elección de instalación de forma lenta y sencilla. Una máquina virtual es el punto de partida más seguro para la mayoría de los nuevos aprendices porque mantiene Kali separado del sistema operativo principal y facilita deshacerse de errores mediante una instantánea.

3.16 Antes de descargar nada

- ✓ Utiliza solo las webs oficiales de Kali Linux y del proveedor de virtualización.
- ✓ Comprueba si tu ordenador usa un procesador Intel/AMD o Apple Silicon. Los Macs con Apple Silicon utilizan imágenes ARM64.
- ✓ Asegúrate de que los archivos importantes estén respaldados antes de cambiar particiones, realizar ajustes de firmware o activar funciones de virtualización.
- ✓ Para un laboratorio de seguridad Kali normal, planifica al menos 8 GB de memoria del host; 16 GB es mucho más cómodo.
- ✓ Reserva al menos 80 GB de almacenamiento libre para cada máquina virtual. Los modelos locales de IA pueden requerir mucho más espacio.

[Descargas oficiales de Kali](#)

[Cómo verificar una imagen oficial de Kali](#)

3.17 Elige la imagen correcta de Kali

Abre la página oficial de descarga de Kali antes de elegir una imagen.

- ✓ **Para VMware, VirtualBox o Hyper-V en un ordenador con Windows de 64 bits (Intel o AMD), elige la imagen AMD64 de 64 bits.**
- ✓ **Para un Mac Apple Silicon, como un M1, M2, M3 o un modelo más reciente, elige la imagen instaladora ARM64.**
- ✓ **Para VMware y VirtualBox, la imagen oficial preconstruida de la máquina virtual suele ser la más sencilla porque Kali ya está instalado.**
- ✓ **Para Hyper-V, usa la imagen oficial del Instalador en una partición separada o en un ordenador dedicado, a menos que Kali proporcione una imagen preconstruida actual que coincida exactamente con tu plataforma.**
- ✓ Registra dónde se guarda el archivo descargado. La mayoría de los navegadores lo guardan en la carpeta de Descargas.

3.18 VMware Workstation en Windows: la opción más fácil para muchos principiantes

Utiliza este método cuando quieras una integración sólida en el escritorio, instantáneas y soporte directo para dispositivos USB. Los nombres de los botones pueden variar ligeramente según la versión de VMware.

[Descargar VMware Workstation](#)

[Descarga la imagen oficial de Kali VMware](#)

[Guía de Kali para importar la imagen preconstruida de VMware](#)

1. **Comprueba que la virtualización de hardware esté activada. En Windows, abre el Administrador de tareas, elige Rendimiento y selecciona CPU. Busca "Virtualización: Habilitada."**
2. **Instala VMware Workstation desde la página web oficial de VMware. Reinicia Windows si el instalador te lo pide.**
3. **Descarga el archivo oficial de Kali para VMware AMD64. No descargues un archivo de un espejo desconocido o descripción de vídeo.**
4. **Usa 7-Zip para extraer el archivo .7z descargado. En Windows 11, haz clic con el botón derecho en el archivo y elige "Mostrar más opciones" si el menú de 7-Zip está oculto.**

5. **Abre VMware Workstation.** Elige Abrir una máquina virtual y luego selecciona el archivo .vmx de la carpeta Kali extraída.
6. **Antes de empezar con Kali,** abre la configuración de la máquina virtual. Una buena configuración para principiantes es de 4 núcleos de procesador, 8 GB de memoria y el tamaño del disco indicado en la imagen.
7. **Mantén el adaptador de red configurado en modo NAT** durante las primeras clases. NAT permite a Kali acceder a Internet a través del host mientras reduce la exposición directa a la red local.
8. **Arranca la máquina virtual.** La imagen oficial precompilada puede usar inicialmente kali tanto como nombre de usuario como contraseña. Cambia la contraseña inmediatamente.
9. **Ejecuta las actualizaciones del sistema,** apaga Kali de forma limpia y crea una instantánea llamada "Clean Install". Esto te da un punto de recuperación seguro.
10. **No actives carpetas compartidas ni arrastres y sueltas hasta que entiendas el riesgo para la privacidad.**
Las funciones compartidas pueden exponer archivos del anfitrión al sistema invitado.

3.19 Hyper-V en Windows 11 Pro, Enterprise o Education

Usa Hyper-V cuando ya forme parte de tu entorno de Windows. Windows Home normalmente no incluye la función completa de Hyper-V. Hyper-V también puede afectar el funcionamiento de otros productos de virtualización, así que utiliza siempre una plataforma principal cuando sea posible.

[Requisitos y configuración de Microsoft Hyper-V](#)

[Guía oficial de instalación de Kali Hyper-V](#)

[Guía oficial de importación preconstruida de Kali para Hyper-V](#)

[Guía del Modo Sesión Mejorada de Kali](#)

1. **Abre Windows Search y escribe "Activar o desactivar las funciones de Windows".**
2. **Selecciona Hyper-V,** incluyendo Herramientas de Gestión de Hyper-V y la Plataforma Hyper-V. Elige OK y reinicia el ordenador.
3. **Abre Hyper-V Manager desde el menú Inicio.**
4. **Elige Nuevo y luego Máquina Virtual.** Dale a la máquina virtual un nombre claro como Kali-Lab.
5. **Elige Generación 2 a menos que la documentación actual de Kali te indique específicamente otra opción.**
6. **Asigna memoria de arranque.** Ocho GB es un valor cómodo para principiantes cuando el anfitrión cuenta con al menos 16 GB. La memoria dinámica puede activarse cuando el host requiere flexibilidad.
7. **Conecta la máquina virtual al Switch por defecto para una conexión sencilla a Internet mediante NAT.**
8. **Crea un disco duro virtual de al menos 80 GB.** Elige un disco más grande si planeas instalar modelos de IA locales.
9. **Adjunta el ISO oficial del instalador de Kali,** o sigue la guía de importación preconstruida actual de Kali para Hyper-V.
10. **Si la máquina virtual no arranca,** revisa la configuración de arranque seguro. La documentación de Kali puede indicarte que desactives el arranque seguro en esa máquina virtual o que selecciones una plantilla de certificado compatible.
11. **Completa el instalador gráfico de Kali.** Usa la opción guiada que utiliza todo el disco virtual. Este disco virtual es solo un archivo; no es la unidad física de Windows.
12. **Después de la primera actualización exitosa,** crea un punto de control de Hyper-V llamado "Clean Install".

13. **Para mejorar el redimensionamiento y el comportamiento del portapapeles, sigue la guía oficial del Modo de Sesión Mejorada y usa kali-tweaks en Kali.**

3.20 Oracle VirtualBox en Windows, Linux o Mac Intel

VirtualBox es gratuito y muy utilizado. Es una buena opción cuando VMware o Hyper-V no están disponibles, aunque el comportamiento de USB y gráficos puede requerir más configuración.

[Descargar Oracle VirtualBox](#)

[Descarga la imagen oficial de Kali VirtualBox](#)

[Guía de Kali para importar la imagen preconstruida de VirtualBox](#)

[Guía de instalación de invitados de Kali VirtualBox](#)

1. **Descarga e instala VirtualBox desde la página web oficial de Oracle.**
2. **Descarga el archivo oficial de Kali para VirtualBox y extráelo con 7-Zip u otra herramienta de archivos confiable.**
3. **Abre VirtualBox y elige Añadir. Navega hasta la carpeta extraída de Kali y selecciona el archivo .vbox.**
4. **Abre la configuración de la máquina virtual. Asigna unos 4 núcleos de CPU y 8 GB de memoria cuando el host disponga de recursos suficientes.**
5. **Usa redes NAT para las primeras clases.**
6. **Empieza Kali y inicia sesión. Cambia la contraseña predeterminada si usa la imagen.**
7. **Actualiza Kali, apágalo y crea una instantánea llamada "Clean Install".**
8. **Si la pantalla no se redimensiona correctamente, confirma que los paquetes invitados de VirtualBox están instalados. Kali normalmente los instala automáticamente en las configuraciones de las máquinas virtuales compatibles.**
9. **Instala el Oracle Extension Pack solo cuando necesites sus funciones y su versión coincida exactamente con la de VirtualBox instalada.**

3.21 Kali en Apple Silicon Mac - M1, M2, M3 y versiones posteriores

Los Mac con Apple Silicon utilizan procesadores ARM64. Una imagen de Kali para AMD64 no es la opción correcta para la virtualización normal en estos Macs.

[Descargas del instalador Kali ARM64](#)

[VMware Fusion para Mac](#)

[Guía de Kali VMware Fusion para Apple Silicon](#)

[Escritorio de Parallels](#)

[Guía de Kali en Paralelos](#)

[UTM para Mac](#)

[Guía de Kali en UTM](#)

1. **Abre el menú Apple, elige Acerca de este Mac y confirma que en el ordenador aparece un chip Apple M-series.**
2. **Elige un producto de virtualización: VMware Fusion, Parallels Desktop o UTM. Instálalo desde la web oficial del vendedor.**
3. **Descarga el instalador ISO de Kali ARM64. No elijas AMD64 como máquina virtual Apple Silicon.**
4. **Crea una nueva máquina virtual y selecciona Linux u otro Linux ARM64 cuando se te pida el tipo de sistema operativo.**
5. **Asigna al menos 4 núcleos de procesador, 8 GB de memoria y 80 GB de almacenamiento cuando el Mac tenga suficiente capacidad.**
6. **Conecta el ISO del ARM64 y arranca la máquina virtual.**

7. Usa el instalador gráfico para instalar Kali en el disco virtual de la máquina virtual.
8. Tras la primera actualización, instala las herramientas de integración de invitados recomendadas por el producto de virtualización elegido.
9. Crea una instantánea antes de añadir herramientas de seguridad o de cambiar ajustes importantes.
10. Recuerda que algunas herramientas de seguridad o controladores pueden comportarse de manera diferente en ARM64. Consulta la documentación oficial de la herramienta cuando no esté disponible ningún paquete.

3.22 Mac basado en Intel

Los Mac Intel suelen usar la imagen de Kali de 64 bits. Se pueden usar VMware Fusion, VirtualBox o Parallels dependiendo del soporte actual del fabricante para la versión de macOS.

[Documentación de virtualización de Kali](#)

1. Confirma que About This Mac identifica un procesador Intel.
2. Instala un programa de virtualización compatible desde su página web oficial.
3. Descarga la imagen oficial de Kali para AMD64 o el ISO del instalador.
4. Crea o importa la VM, luego asigna recursos razonables de memoria, procesador y disco.
5. Usa primero la red NAT, actualiza Kali y crea una instantánea limpia.

3.23 Partición separada o arranque dual con Windows

Este método da a Kali acceso directo al hardware, pero conlleva más riesgos que una máquina virtual. Un error de partición puede impedir que ni Windows ni los archivos personales estén disponibles. Los nuevos aprendices normalmente deberían practicar primero en una VM.

[Guía oficial de Kali para botas dobles](#)

[Guía oficial de instalación del disco duro de Kali](#)

1. Haz una copia de seguridad de todos los archivos importantes en un disco separado o en un servicio en la nube de confianza.
2. Guarda la clave de recuperación de BitLocker de Windows. No continúes hasta saber dónde está guardada esa llave.
3. Crea una unidad de recuperación de Windows y confirma que Windows arranca con normalidad.
4. Desactiva el inicio rápido de Windows. El arranque rápido puede dejar las particiones de Windows en un estado que Linux no debería modificar.
5. Abre la Gestión de Discos de Windows y reduce la partición de Windows. Deja el nuevo espacio sin asignar; no lo formatees en Windows.
6. Descarga el ISO oficial del instalador de Kali y verifica su suma de comprobación.
7. Crea una unidad USB de arranque con un programa de imagen de confianza. Asegúrate de seleccionar la memoria USB, no el disco principal del ordenador.
8. Reinicia el ordenador y abre el menú de arranque UEFI. Elige el dispositivo USB en modo UEFI.
9. Inicia el instalador gráfico. Cuando aparezca la partición, elige la opción que utilice el mayor espacio libre continuo, o selecciona manualmente solo el espacio no asignado.
10. Nunca elijas usar el disco completo cuando Windows y archivos personales deban permanecer en el ordenador.
11. Permite al instalador configurar el menú de arranque de GRUB. Después de la instalación, prueba tanto Kali como Windows.
12. Si Windows solicita la clave de recuperación de BitLocker tras cambiar la configuración de arranque, introduce la clave que guardaste.

13. **Actualiza Kali y deja disponible el USB de recuperación. No elimines la copia de seguridad de Windows tras un solo arranque exitoso.**

3.24 Instalación de ordenadores dedicados

Un ordenador dedicado es una opción sólida a largo plazo para adaptadores inalámbricos, dispositivos USB, trabajo con GPU y acceso completo al hardware. El ordenador no debe contener datos importantes antes de la instalación.

1. **Respalda todo lo que deba conservarse. La instalación puede borrar todo el disco.**
2. **Descarga y verifica el ISO oficial del instalador de Kali.**
3. **Crea el USB de arranque y arranca el ordenador desde él.**
4. **Elige Instalación gráfica.**
5. **Selecciona el idioma, la ubicación, el teclado, la cuenta de usuario y la información de la zona horaria.**
6. **Cuando aparezca la partición, usa Guiada: usa el disco completo solo cuando el ordenador esté realmente dedicado a Kali y no contenga el sistema operativo ni los archivos necesarios.**
7. **Utiliza LVM cifrado cuando el ordenador pueda almacenar notas o pruebas sensibles y así podrás gestionar la frase de contraseña del cifrado con seguridad.**
8. **Completa la instalación, quita el USB cuando se lo pida y reinicia. Actualiza a Kali antes de instalar herramientas adicionales.**

3.25 Primera lista de comprobación de arranque para cada instalación

1. Abre un terminal.
2. Ejecuta `sudo apt update` para actualizar las listas de paquetes.
3. Ejecuta `sudo apt full-upgrade -y` para instalar las actualizaciones disponibles. Lee los comandos antes de aceptar cambios inusuales.
4. Reinicia Kali tras una actualización importante del kernel o del sistema.
5. Confirma la fecha, la hora, el teclado, la red y la resolución de la pantalla.
6. Crea una instantánea o un punto de control si Kali se ejecuta como máquina virtual.
7. Crea una carpeta para laboratorios y apuntes. Mantén los datos de clientes o datos personales fuera de los ejercicios para principiantes.
8. Usa redes NAT hasta que una lección explique por qué se necesita otro tipo de red.
9. Nunca conectes una herramienta de seguridad a un objetivo real solo para ver qué pasa.

3.26 Enlaces de virtualización en un vistazo

Plataforma o recurso	Enlace oficial
Descargas de Kali	Recurso oficial - kali.org
VMware Workstation/Fusion	Recurso oficial - vmware.com
Oracle VirtualBox	Recurso oficial - virtualbox.org
Microsoft Hyper-V	Recurso oficial - learn.microsoft.com
Escritorio de Parallels	Recurso oficial - parallels.com
UTM para Mac	Recurso oficial - mac.getutm.app
Guías de virtualización de Kali	Recurso oficial - kali.org

4. Construir un laboratorio de prácticas seguras

Construir un laboratorio de prácticas seguras

Un laboratorio seguro te permite cometer errores. Separa los objetivos de práctica de los sistemas reales para permitir la recuperación. El laboratorio más sencillo consiste en una máquina virtual de Kali y un objetivo asignado en Hack The Box. Un laboratorio local puede añadir máquinas virtuales o contenedores intencionalmente vulnerables a una red aislada compuesta únicamente por hosts.

Nunca uses un objetivo público como sustituto

Un tutorial que muestre TARGET_IP no te autoriza a reemplazarlo por una escuela, un empleador, una página web pública, un vecino o cualquier otra dirección de Internet.

4.1 Hack The Box como área principal de práctica

Figura 2. El camino seguro desde el ordenador del alumno hasta el objetivo asignado para hackear la caja. Hack The Box Starting Point está diseñado para principiantes absolutos y ofrece máquinas guiadas con explicaciones. Los estudiantes pueden conectarse a través de OpenVPN desde Kali o usar Pwnbox, un entorno basado en el navegador. Sigue las normas vigentes de la plataforma y nunca publiques soluciones restringidas de máquina activa, señales, credenciales ni spoilers.

[Punto de partida de Hack The Box](#)

[HTB Empezando](#)

[Academia HTB](#)

[Reglas de la Plataforma HTB](#)

[Introducción a Pwnbox](#)

4.2 Flujo de trabajo seguro de HTB

Sigue esta secuencia para cada sesión autorizada del laboratorio de Hack The Box:

1. **Inicia sesión y elige una máquina Starting Point u otro laboratorio que tengas permitido usar.**
2. **Inicia o genera el objetivo y registra la dirección IP asignada.**
3. **Descarga tu configuración de VPN o abre Pwnbox.**
4. **Crea una carpeta local de pruebas con el nombre del laboratorio.**
5. **Conéctate a la VPN y confirma la conexión.**
6. **Verifica la IP de destino antes de cada comando.**
7. **Empieza por el descubrimiento de bajo impacto.**
8. **Registra los hallazgos y las razones de cada paso siguiente.**
9. **Para el objetivo y desconecta cuando termines.**

```
mkdir -p ~/labs/starting-point/example/{notes, scans,
evidence} cd ~/labs/starting-point/example sudo openvpn
/path/to/your-lab.ovpn
```

Proteger el archivo VPN

Tu archivo.ovpn puede contener información de acceso específica de la cuenta. No lo subas a GitHub, no lo pegues en herramientas públicas de IA ni lo compartas con otra persona.

5. Herramientas de IA para el aprendizaje en ciberseguridad

Herramientas de IA para el aprendizaje en ciberseguridad

Figura 3. Los controles de seguridad deben proteger todo el flujo de trabajo de la IA.

La IA puede ayudar a un principiante a interpretar resultados, organizar apuntes, formular preguntas de estudio y comparar documentación. También puede ser erróneo, demasiado confiado, inseguro o no contar con tu autorización. Trátalo como un asistente de estudio, no como una autoridad ni como un sistema de permisos.

Regla de seguridad de la IA

Nunca subas credenciales reales, archivos VPN, tokens, datos de clientes, malware de origen desconocido, pruebas forenses privadas o resultados de escaneos confidenciales a un servicio público de IA.

5.1 Ollama

CORREDOR LOCAL DE MODELOS

Qué es y por qué importa

Ejecuta modelos de lenguaje compatibles en el propio ordenador del aprendiz. Útil cuando la privacidad o el acceso offline importan y el ordenador dispone de suficiente memoria.

Cuándo usarlo

- ✓ Explicando la salida de comandos limpia localmente.
- ✓ Crear preguntas de estudio a partir de tus propios apuntes.
- ✓ Redactar un resumen de remediación sin subir datos.

Cuándo no usarlo

No asumas que “local” significa que es perfectamente seguro. Los modelos grandes pueden abrumar a un ordenador antiguo.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
Ollama --Versión
```

```
Lista de Ollama
```

Primer ejercicio seguro

Instala desde la fuente oficial de Ollama, inicia el servicio, descarga un modelo pequeño y pídele que te explique un comando inofensivo como 'ip addr'.

Qué buscar

¿La respuesta distingue entre una dirección IP, una interfaz y un dispositivo de loopback? ¿Puedes confirmar tu explicación con 'man ip' o con la documentación oficial?

Errores comunes de principiantes: descargar un modelo demasiado grande. Tratar una respuesta plausible como un hecho verificado.

Nivel de riesgo

Bajo riesgo operativo al usarlo con datos no sensibles. El uso de recursos puede ser alto.

Usar la IA de forma responsable con esta herramienta

Pide a la IA que explique el resultado y luego verifica esa explicación con la ayuda de la herramienta, de la página del manual o de la documentación oficial. Elimina direcciones IP, nombres de usuario, secretos y detalles únicos del cliente antes de compartir la salida externa.

Recursos oficiales

[Ollama](#)

5.2 Open WebUI

INTERFAZ DE NAVEGADOR PARA MODELOS DE IA LOCALES O CONECTADOS

Qué es y por qué importa

Proporciona una interfaz de chat familiar y se puede conectar con Ollama y otros backends compatibles. Útil para estudiantes que prefieren una interfaz en navegador y quieren conversaciones organizadas.

Cuándo usarlo

Mantener chats de estudio separados para networking, seguridad web y forense. Utilizando un modelo local mediante una interfaz gráfica.

Cuándo no usarlo

No expongas Open WebUI a Internet sin una seguridad sólida. No subas secretos ni pruebas sin entender cómo funciona el almacenamiento.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
Docker --Version
Docker PS
```

Primer ejercicio seguro

Ejecuta Open WebUI en un contenedor Docker local, conéctalo a Ollama y crea una conversación de estudio que contenga solo datos ficticios.

Qué buscar

1. ¿Puede la interfaz llegar al modelo seleccionado?
2. ¿Dónde se almacenan las conversaciones?
3. ¿Puede otro usuario del host acceder a ellos?

Errores comunes de principiantes

Publicar el servicio en todas las interfaces. Usar un comando de contenedor no confiable sin revisión previa.

Nivel de riesgo

Riesgo de configuración medio. Un servicio poco expuesto puede generar problemas de privacidad y de control de acceso.

Usar la IA de forma responsable con esta herramienta

Pide a la IA que explique el resultado y luego verifica esa explicación con la ayuda de la herramienta, de la página del manual o de la documentación oficial. Elimina direcciones IP, nombres de usuario, secretos y detalles únicos del cliente antes de compartir la salida externa.

Recursos oficiales

[Documentación de OpenWebUI](#)

5.3 Promptfoo

EVALUACIÓN DE LA LLM Y MARCO DEL EQUIPO ROJO

Qué es y por qué importa

Ejecuta pruebas reproducibles contra prompts, modelos y aplicaciones de IA. Útil para comprobar si un sistema de IA gestiona de forma consistente los prompts inseguros o adversariales.

Cuando usarlo

- ✓ Comparando las respuestas de los modelos sobre el mismo conjunto de pruebas.
- ✓ Probar defensas de inyección rápida en tu propia aplicación.
- ✓ Documentar los criterios de aprobado/suspenso.

Cuando no usarlo

No apuntes a un servicio de IA que no estás autorizado a probar. No envíes avisos confidenciales a proveedores externos.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
promptfoo --version
```

```
promptfoo init
```

Primer ejercicio seguro

Crea una pequeña evaluación local con indicaciones inofensivas: una pregunta normal, una prueba de conflicto de instrucciones y una petición de un secreto inexistente.

Qué buscar

- ✓ ¿El modelo seguía la instrucción prevista por el sistema?
- ✓ ¿Son medibles los criterios del examen?
- ✓ ¿Puede otro aprendiz reproducir el resultado?

Errores comunes de principiantes

Confundir una demostración con una evaluación completa de la seguridad. Usando afirmaciones vagas que siempre pasan.

Nivel de riesgo

Riesgo medio. Las pruebas pueden enviar un gran número de solicitudes o textos sensibles a los proveedores.

Usar la IA de forma responsable con esta herramienta

Pide a la IA que explique el resultado y luego verifica esa explicación con la ayuda de la herramienta, de la página del manual o de la documentación oficial. Elimina direcciones IP, nombres de usuario, secretos y detalles únicos del cliente antes de compartir la salida externa.

Recursos oficiales

[Documentación de Promptfoo](#)

5.4 Giskard

KIT DE HERRAMIENTAS PARA PRUEBAS Y EVALUACIÓN DE IA

Qué es y por qué importa

Ayuda a evaluar sistemas de aprendizaje automático e IA generativa para detectar problemas de calidad y seguridad. Útil cuando un proyecto requiere pruebas estructuradas, informes y comprobaciones repetibles.

Cuando usarlo

Probar un modelo o un agente que tengas. Incorporando controles de calidad y seguridad en el proceso de desarrollo.

Cuando no usarlo

No instales paquetes globalmente cuando un entorno virtual sea más apropiado. No asumas que todos los resultados del escáner sean vulnerabilidades confirmadas.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
python3 -m venv .venv fuente
.venv/bin/activate python -m
pip show giskard
```

Primer ejercicio seguro

Crea un entorno virtual, instala solo el conjunto de paquetes necesario y ejecuta un ejemplo documentado sobre datos de muestra no sensibles.

Qué buscar

- ✓ ¿Qué examen suspendió?
- ✓ ¿Qué pruebas respaldan el fracaso?
- ✓ ¿Se puede reproducir manualmente?

Errores comunes de principiantes

Mezclando entornos Python incompatibles. Publicar datos de prueba que contengan información privada.

Nivel de riesgo

Riesgo medio, principalmente relacionado con las dependencias, el manejo de datos y las llamadas a modelos externos.

Usar la IA de forma responsable con esta herramienta

Pide a la IA que explique el resultado y luego verifica esa explicación con la ayuda de la herramienta, de la página del manual o de la documentación oficial. Elimina direcciones IP, nombres de usuario, secretos y detalles únicos del cliente antes de compartir la salida externa.

Recursos oficiales

[Documentación de Giskard](#)

5.5 LangChain

MARCO PARA APLICACIONES BASADAS EN MODELOS

Qué es y por qué importa

Proporciona componentes para prompts, herramientas, recuperación, memoria y agentes. Útil para construir un proyecto de aprendizaje controlado que conecte un modelo con documentos o funciones.

Cuando usarlo

Creando una pequeña demostración de RAG a partir de notas públicas. Aprender cómo los agentes seleccionan herramientas.

Cuando no usarlo

No concedas acceso de shell sin restricciones a un agente experimental. No lo uses como límite de seguridad.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
Python -m Mostran LangChain
```

Primer ejercicio seguro

Crea una aplicación mínima que responda preguntas a partir de un archivo público corto. Mantén las herramientas desactivadas durante el primer ejercicio.

Qué buscar

- ✓ ¿La respuesta menciona el texto proporcionado?
- ✓ ¿Qué ocurre cuando la respuesta no existe?
- ✓ ¿Puede el modelo inventar una fuente?

Errores comunes de principiantes

Empezando por un agente autónomo complejo. Ignorando los cambios de dependencia y versión.

Nivel de riesgo

Riesgo medio a alto cuando los agentes pueden invocar herramientas o acceder a datos sensibles.

Usar la IA de forma responsable con esta herramienta

Pide a la IA que explique el resultado y luego verifica esa explicación con la ayuda de la herramienta, de la página del manual o de la documentación oficial. Elimina direcciones IP, nombres de usuario, secretos y detalles únicos del cliente antes de compartir la salida externa.

Recursos oficiales

[Documentación de LangChain](#)

5.6 LlamaIndex

MARCO DE DATOS Y RECUPERACIÓN

Qué es y por qué importa

Ayuda a conectar modelos de lenguaje con documentos, índices y flujos de trabajo de recuperación. Útil para aprender sobre RAG y las implicaciones de seguridad asociadas a fuentes de conocimiento poco fiables.

Cuando usarlo

Indexación de apuntes públicos de curso. Comprobar si los pasajes recuperados respaldan la respuesta.

Cuando no usarlo

No insinúas evidencia privada en un camino modelo externo. No confíes en el texto recuperado como instrucciones.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
Python -m pip mostrar índice llama
```

Primer ejercicio seguro

Indexa un pequeño conjunto de archivos de texto públicos y haz preguntas con respuestas que citen los pasajes recuperados.

Qué buscar

- ✓ ¿Se recuperó el pasaje correcto?
- ✓ ¿Una instrucción incrustada cambió el comportamiento del modelo?
- ✓ ¿Cómo se controla el acceso al código fuente?

Errores comunes de principiantes: confundir la relevancia de la recuperación con la verdad.
No separar datos de instrucciones.

Nivel de riesgo

Riesgo medio. RAG puede filtrar datos indexados o transportar la inyección inmediata de documentos.

Usar la IA de forma responsable con esta herramienta

Pide a la IA que explique el resultado y luego verifica esa explicación con la ayuda de la herramienta, de la página del manual o de la documentación oficial. Elimina direcciones IP, nombres de usuario, secretos y detalles únicos del cliente antes de compartir la salida externa.

Recursos oficiales

[Documentación de LlamaIndex](#)

5.7 Ayuda

PROGRAMADOR DE PAREJAS DE IA BASADO EN TERMINALES

Qué es y por qué importa

Ayuda a editar código en un repositorio de Git con modelos de IA compatibles. Útil para entender cambios de código, crear pruebas y aprender hábitos de revisión seguros.

Cuándo usarlo

- ✓ Mejorar un breve guion de laboratorio.
- ✓ Añadiendo manejo de errores y comentarios.
- ✓ Revisar un parche propuesto antes de aceptarlo.

Cuando no usarlo

No lo ejecutes en un repositorio que contenga secretos. No aceptes cambios sin leer el diferencial.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
aider --version  
git status
```

Primer ejercicio seguro

Crea un repositorio Git desechable que contenga un script Python inofensivo, pide a Aider que añada validación de entrada y revisa la diferencia.

Qué buscar

1. ¿Qué archivos cambiaron?
2. ¿El cambio añadió dependencias?
3. ¿Aun así se aprueban los exámenes?

Errores comunes de principiantes

Dejar que la herramienta edite el repositorio incorrecto. Hacer commit de secretos generados o código inseguro.

Nivel de riesgo

Riesgo medio. Puede modificar numerosos archivos y enviar código a un proveedor de modelos.

Usar la IA de forma responsable con esta herramienta

Pide a la IA que explique el resultado y luego verifica esa explicación con la ayuda de la herramienta, de la página del manual o de la documentación oficial. Elimina direcciones IP, nombres de usuario, secretos y detalles únicos del cliente antes de compartir la salida externa.

Recursos oficiales

[Documentación de ayuda](#)

5.8 Intérprete abierto

INTERFAZ EN LENGUAJE NATURAL QUE PUEDE EJECUTAR CÓDIGO LOCAL

Qué es y por qué importa

Permite que una sesión asistida por un modelo ejecute código e interactúe con el ordenador local. Útil solo en un entorno desechable y bien estructurado cuando el aprendiz entiende que los comandos generados pueden ejecutarse.

Cuando usarlo

Realizar transformaciones inofensivas de datos en una carpeta de laboratorio. Aprender a revisar los comandos propuestos antes de ejecutarlos.

Cuando no usarlo

No lo uses en un ordenador principal con archivos valiosos. No concedas acceso amplio a credenciales, perfiles de navegador ni pruebas privadas.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
interprete --version
```

Primer ejercicio seguro

Usa una instantánea de VM desechable y una carpeta con datos CSV ficticios. Pide un resumen y aprueba solo los comandos que entiendas.

Qué buscar

- ✓ ¿Qué comando se ejecutará?
- ✓ ¿A qué archivos puede acceder?
- ✓ ¿Se puede hacer la tarea sin privilegios elevados?

Errores comunes de principiantes

1. Aprobando órdenes automáticamente.
2. Corriendo como root.
3. Suponiendo que una solicitud en lenguaje natural no pueda borrar archivos.

Nivel de riesgo

Alto riesgo en comparación con un chatbot normal, ya que puede ejecutar código y modificar archivos.

Usar la IA de forma responsable con esta herramienta

Pide a la IA que explique el resultado y luego verifica esa explicación con la ayuda de la herramienta, de la página del manual o de la documentación oficial. Elimina direcciones IP, nombres de usuario, secretos y detalles únicos del cliente antes de compartir la salida externa.

Recursos oficiales

[Documentación de Open Interpreter](#)

6. MCP, RAG y agentes de IA

6.1 RAG en lenguaje claro

La generación aumentada por recuperación, comúnmente llamada RAG, permite a una aplicación buscar documentos aprobados e incorporar fragmentos relevantes en un modelo de indicación. El modelo, entonces, utiliza esos pasajes al generar una respuesta. RAG puede mejorar la precisión, pero también puede exponer documentos al usuario equivocado si los permisos están mal diseñados.

6.2 Bases de datos vectoriales en lenguaje sencillo

Una base de datos vectorial almacena representaciones numéricas de texto para que una aplicación pueda encontrar contenido con un significado similar. Ejemplos incluyen Chroma, FAISS y Qdrant. La cuestión de seguridad no se reduce a saber si la base de datos está cifrada. La aplicación también debe comprobar si el usuario actual puede recuperar cada documento fuente.

6.3 Agentes y uso de herramientas

Un agente de IA puede elegir acciones, llamar a APIs, acceder a archivos de búsqueda o ejecutar herramientas. Esto hace que el sistema sea útil, pero también incrementa el riesgo. Un agente debe contar con los permisos mínimos necesarios, requerir aprobación para acciones de alto impacto y mantener registros fiables.

6.4 Protocolo de Contexto de Modelo (MCP): un principio fundamental de seguridad en IA

Figura 4. Componentes MCP y controles necesarios en cada límite de confianza.

El Protocolo de Contexto de Modelo, o MCP, es una forma de que las aplicaciones de IA se conecten a herramientas y fuentes de datos mediante una interfaz consistente. Trata cada servidor MCP como una integración de software que requiere autenticación, autorización, registro, validación de entrada y una revisión cuidadosa de los datos y las acciones que expone.

6.5 Por qué el MCP es importante para los empleadores

Los sistemas modernos de IA necesitan cada vez más acceso controlado a herramientas, archivos, bases de datos, servicios en la nube y aplicaciones empresariales. MCP proporciona un marco común para que una aplicación de IA descubra y utilice dichas capacidades. Los empleadores necesitan personas que sepan no solo cómo conectar un servidor MCP, sino también cómo decidir qué herramientas debe usar la IA, a qué datos puede acceder y cómo se registrarán y revisarán cada acción.

6.6 Los principios de seguridad detrás de MCP

Trata cada servidor MCP como un límite de seguridad. Dale el conjunto mínimo de permisos necesario para su propósito. Autenticar usuarios y servicios, validar todas las entradas, proteger secretos, restringir el acceso a archivos y a la red, mantener registros de auditoría y requerir la aprobación humana para acciones que puedan cambiar datos, enviar mensajes, ejecutar código o afectar a sistemas de producción. Una conexión MCP útil no es automáticamente segura.

6.7 Una lista de comprobación para principiantes de reseñas de MCP

1. ¿Qué problema de negocio resuelve este servidor MCP?
2. ¿A qué herramientas y fuentes de datos puede acceder?
3. ¿Cómo se autentican los usuarios, las aplicaciones y los servidores?
4. ¿Los permisos están limitados al mínimo requerido?
5. ¿Podrían los prompts o documentos no confiables activar una llamada peligrosa a una herramienta?
6. ¿Qué acciones requieren que una persona las apruebe?
7. ¿Se registran las llamadas a herramientas, los errores y el acceso a datos en los registros de auditoría?
8. ¿Cómo puede desactivarse rápidamente la conexión durante un incidente?

6.8 Agentes de IA: la idea básica

Un agente de IA es un software que utiliza un modelo de IA para alcanzar un objetivo. Un chatbot suele responder a una pregunta. Un agente puede ir más allá eligiendo el siguiente paso: leer información, llamar a una herramienta, crear un ticket, enviar un mensaje o cambiar un recurso en la nube. El modelo proporciona razonamiento y lenguaje; las herramientas proporcionan la capacidad de actuar.

La idea de seguridad más importante es sencilla: un agente puede cometer errores, malinterpretar instrucciones o seguir instrucciones maliciosas ocultas en un documento, una página web, un correo electrónico o una respuesta de una herramienta. Por eso, nunca se debe confiar en un agente solo porque suene seguro.

6.9 Los riesgos que todo empleador debería comprender

- ✓ Inyección de prompt: un texto malicioso puede intentar modificar las instrucciones del agente.
- ✓ Permisos excesivos: un agente puede leer, modificar o eliminar más de lo que su trabajo requiere.
- ✓ Fuga de datos: la información sensible puede filtrarse en prompts, registros, memoria, llamadas a herramientas o respuestas de los modelos.
- ✓ Uso inseguro de herramientas: el agente puede enviar correos electrónicos, ejecutar código, aprobar transacciones o modificar un sistema de forma incorrecta.
- ✓ Conocimiento no fiable: los documentos o sitios web utilizados por el agente pueden contener información falsa o instrucciones ocultas.
- ✓ Monitorización débil: una organización puede no saber a qué accedió, qué decidió o qué cambió el agente.
- ✓ Coste y disponibilidad: los bucles, las llamadas repetidas a herramientas o las solicitudes muy grandes pueden generar costes inesperados o interrupciones del servicio.

6.10 Microsoft Azure y Microsoft Foundry: fundamentos de la seguridad

En Azure, un empleador puede crear agentes con Microsoft Foundry Agent Service y conectarlos a datos, aplicaciones y herramientas de Azure. Las protecciones básicas son las mismas que se usan en otros sistemas empresariales: otorgar al agente su propia identidad gestionada, aplicar el principio de privilegio mínimo mediante el control de acceso basado en roles de Azure, almacenar secretos en un servicio protegido como Azure Key Vault, restringir el acceso a la red y registrar la actividad.

Utiliza controles de seguridad de contenido y escudos de prompt cuando sea apropiado para ayudar a detectar contenido dañino, intentos de fuga y ataques de inyección rápida. Requiere la aprobación humana antes de que un agente cambie los datos de producción, envíe comunicaciones externas, ejecute código o realice cualquier otra acción de alto impacto. Envía registros y alertas relevantes a los sistemas de monitorización y respuesta a incidentes de la organización.

6.11 AWS y Amazon Bedrock: fundamentos de seguridad

En AWS, los agentes pueden usar Amazon Bedrock y conectarse a bases de conocimiento, funciones de Lambda, APIs, bases de datos y otros servicios. Asigna a cada agente un rol de IAM con un alcance limitado, en lugar de un

acceso de administrador amplio. Utiliza entornos separados para desarrollo y producción, protege los datos mediante cifrado y restringe las rutas de red a los sistemas que el agente realmente necesita.

Amazon Bedrock Guardrails puede ayudar a filtrar contenido inseguro y detectar ataques de prompt, pero los guardrails son solo una capa. Validar las entradas y salidas de herramientas, limitar el número de acciones que puede realizar un agente, establecer límites de tiempo y de gasto, registrar las indicaciones y las llamadas de las herramientas conforme a las normas de privacidad, y exigir aprobación para acciones con impacto financiero, legal, de seguridad u operativo.

6.12 API OpenAI y flujos de trabajo conectados a ChatGPT: fundamentos de la seguridad

Cuando un empleador utiliza modelos de OpenAI, el riesgo principal normalmente no se limita al modelo. El mayor riesgo surge cuando el modelo está conectado a archivos de la empresa, correo electrónico, navegadores, bases de datos, código o herramientas externas. Trata cada conector y cada herramienta como un límite de seguridad. Permite solo los datos y las acciones necesarios para el propósito empresarial aprobado.

Mantén las instrucciones y credenciales del sistema fuera del contenido visible para el usuario, valida los argumentos de la herramienta en el servidor y no dejes que el modelo tome las decisiones finales de autorización. Añadir confirmación antes de realizar acciones sensibles, proteger contra la exfiltración de datos mediante enlaces o llamadas a herramientas, separar las instrucciones confiables del contenido no confiable y conservar suficiente información de auditoría para investigar qué ocurrió.

6.13 Una lista mínima de comprobación para empleadores de agentes de IA

- ✓ Mantén un inventario de cada agente, propietario, modelo, herramienta, fuente de datos y propósito empresarial.
- ✓ Asigna al agente una identidad separada y usa el privilegio mínimo.
- ✓ Clasifica los datos que el agente puede leer, crear, almacenar o transmitir.
- ✓ Trata los prompts, documentos, páginas web, correos electrónicos y respuestas a herramientas como entradas potencialmente no fiables.
- ✓ Permite incluir herramientas aprobadas y validar cada solicitud de herramienta fuera del modelo.
- ✓ Exigir la aprobación humana para acciones destructivas, externas, financieras, legales o de producción.
- ✓ Registra indicaciones, llamadas a herramientas, aprobaciones, resultados y errores respetando los requisitos de privacidad.
- ✓ Prueba para detectar inyección rápida, fuga de datos, agencia excesiva, incumplimiento de la autorización y manejo inseguro de la salida.
- ✓ Establece límites de tarifa, de costes, de tiempos de espera y procedimientos de apagado de emergencia.
- ✓ Revisa el agente tras cambios en el modelo, el prompt, la herramienta, el permiso o la fuente de datos.

Conclusión para principiantes: asegúrate de tratar al agente como a un empleado nuevo que puede trabajar muy rápido, pero que aún necesita una descripción clara del puesto, acceso limitado, supervisión y un registro de acciones importantes.

6.14 Referencias oficiales de inicio

[Microsoft Foundry Agent Service](#)

[Mejores prácticas de seguridad en Azure AI](#)

[AWS Seguridad para IA agente](#)

[AWS Generativa IA seguridad y menor privilegio](#)

[Seguridad de enlaces de agentes OpenAI](#)

Conexión profesional: El conocimiento de MCP resulta útil en la ingeniería de seguridad de IA, la ingeniería de plataformas de IA, la seguridad de agentes, la seguridad de aplicaciones, la seguridad en la nube y la gobernanza de IA. Los principiantes deberían aprender primero las preguntas de arquitectura y seguridad; el despliegue en producción viene después.

6.15 Una lista de verificación sencilla de seguridad para IA

1. Conoce qué datos ingresan al modelo.
2. Sabe dónde se almacenan los prompts y las salidas.
3. Separa las instrucciones confiables del contenido de usuario no confiable.
4. Aplica la autenticación y la autorización normales fuera del modelo.
5. Limita las herramientas y los permisos de los agentes.
6. Escenarios de inyección de prompts de prueba y de fuga de datos.
7. Mantener la aprobación humana para acciones importantes o irreversibles.
8. Monitorizar fallos y crear un proceso de respuesta a incidentes.

7. GRC y Gobernanza de la IA

GRC significa gobernanza, riesgo y cumplimiento. Ayuda a una organización a decidir quién es responsable, qué podría salir mal, qué controles son necesarios y cómo demostrar que cumple con sus obligaciones. El diagrama siguiente muestra la GRC como un ciclo continuo. La gobernanza establece la dirección; la gestión de riesgos identifica y trata la incertidumbre; el cumplimiento y la garantía confirman que los controles funcionan; y la mejora alimenta las lecciones de vuelta al siguiente ciclo.

Figura 7.1 - El GRC es un proceso continuo, no un proyecto único.

7.1 Gobernanza

La gobernanza define la toma de decisiones. Incluye políticas, roles, aprobaciones, propiedad y supervisión. En IA, la gobernanza puede determinar qué herramientas están aprobadas, qué datos pueden utilizarse y quién puede asumir riesgos.

7.2 Riesgo

El riesgo considera lo que podría ocurrir, la probabilidad de que ocurra y la gravedad del resultado. Una buena declaración de riesgos conecta una amenaza, una debilidad y un impacto empresarial.

7.3 Cumplimiento

Cumplir con los requisitos de las leyes, normativas, contratos, políticas internas o normas. Superar una auditoría no significa automáticamente que un sistema sea seguro, pero las pruebas de evidencia y control pueden revelar si las salvaguardas esperadas están funcionando.

7.4 Documentos importantes para principiantes

1. Política: establece lo que exige la organización.
2. Estándar - define una norma técnica u operativa obligatoria.
3. Procedimiento - indica los pasos para completar una tarea.
4. Directriz: proporciona las prácticas recomendadas.
5. Registro de riesgos: registra los riesgos, sus propietarios, las decisiones y los planes de tratamiento.
6. Evidencia de control: muestra que se ejecutó un control, como un informe, un ticket, un registro o una aprobación.

7.5 Preguntas sobre la gobernanza de la IA

1. ¿Tenemos un inventario de sistemas y proveedores de IA?
2. ¿Qué datos se utilizan para el entrenamiento, la recuperación, los prompts y la monitorización?
3. ¿Quién aprueba un nuevo caso de uso de IA?
4. ¿Cómo se proporciona la supervisión humana?
5. ¿Cómo se evalúan los riesgos de sesgo, de privacidad, de seguridad y de propiedad intelectual?
6. ¿Cómo se reportan e investigan los incidentes?
7. ¿Qué pruebas demuestran que los controles están funcionando?

7.6 Marcos a reconocer

- ✓ Marco de Ciberseguridad del NIST
- ✓ Marco de Gestión de Riesgos de IA del NIST
- ✓ ISO/IEC 27001 para la gestión de la seguridad de la información
- ✓ ISO/IEC 42001 para sistemas de gestión de IA
- ✓ Criterios de servicios fiduciarios SOC 2

- ✓ Guía de OWASP para aplicaciones de IA generativa y LLM
- ✓ MITRE ATLAS para amenazas adversariales a sistemas de IA

No intentes memorizar todos los frameworks. Aprende el propósito de cada marco y cómo encajan los controles, la evidencia, la propiedad y las decisiones de riesgo.

8. Herramientas esenciales de seguridad de Kali

8.1 Elegir la herramienta Kali adecuada

Figura 5. Un flujo de trabajo seguro y explicable para pruebas de seguridad.

Kali incluye muchas herramientas, pero los profesionales no las usan todas para cada objetivo. Eligen una herramienta porque responde a una pregunta específica. Un flujo de trabajo sencillo es: descubrir, enumerar, analizar, validar, documentar y recomendar remediaciones.

- ✓ Descubrir: ¿Qué sistemas y servicios están presentes?
- ✓ Enumerar: ¿Qué información se puede obtener de un servicio autorizado?
- ✓ Analizar: ¿Qué sugiere la evidencia?
- ✓ Validar: ¿Se puede confirmar de forma segura la supuesta debilidad?
- ✓ Documento: ¿Qué ocurrió, qué lo demuestra y cuáles son las limitaciones?
- ✓ Remediar: ¿Qué cambio práctico reduciría el riesgo?
- ✓ Parte V - Veinte herramientas esenciales de seguridad Kali
- ✓ Parte VI - Fundamentos de la Forense Digital
- ✓ Parte VII - Informando de lo que aprendes
- ✓ Tus primeros 30 días con Kali Linux

8.2 Veinte herramientas esenciales de seguridad Kali

Esta lista es una selección práctica de aprendizaje, no una afirmación de que una clasificación encaje con todos los profesionales. Cubre descubrimiento, análisis de tráfico, pruebas web, autenticación, trabajo inalámbrico, entornos Windows, investigación de exploits, forense e inteligencia de código abierto.

8.3 Nmap

DESCUBRIMIENTO DE RED E IDENTIFICACIÓN DE SERVICIOS

Qué es y por qué importa

Nmap descubre hosts, escanea puertos y servicios, y obtiene detalles seleccionados del sistema. Ofrece una visión inicial estructurada de un objetivo autorizado y te ayuda a decidir qué investigar a continuación.

Cuando usarlo

Confirmando qué servicios expone una máquina de laboratorio asignada. Revisando tus propios sistemas y la red de laboratorios.

Cuando no usarlo

No escanees redes que no poseas ni para las que tengas permiso para evaluar. Evita las opciones agresivas hasta que entiendas su tráfico e impacto.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
nmap --versión
```

Primer ejercicio seguro

Contra un objetivo HTB asignado, comienza con un escaneo TCP breve y guarda la salida: 'nmap -sV -oN escaneos/initial.txt TARGET_IP'.

Qué buscar

- ✓ Abrir puertos y nombres de servicio.
- ✓ Versiones de servicio que pueden requerir confirmación manual.
- ✓ Puertos filtrados que pueden indicar la presencia de un cortafuegos.

Errores comunes de principiantes

- ✓ Escaneando la IP equivocada.
- ✓ Suponiendo que una cadena de versiones revele una vulnerabilidad.
- ✓ Ejecutando todos los scripts de NSE simultáneamente.

Nivel de riesgo

De bajo a medio, según las opciones. El escaneo puede activar alertas y los scripts agresivos pueden afectar a los servicios.

Recursos oficiales

[Nmap sobre Kali](#)

[Guía de referencia Nmap](#)

8.4 Wireshark

ANÁLISIS DEL TRÁFICO DE RED

Qué es y por qué importa

Wireshark captura y analiza paquetes y protocolos. Permite a los estudiantes ver qué sistemas se intercambian de hecho en una red.

Cuándo usarlo

Resolviendo problemas con la conexión de tu laboratorio. Aprendiendo sobre el comportamiento de DNS, TCP, TLS y HTTP.

Cuándo no usarlo

No captures tráfico cuando no tengas autorización. No recojas las credenciales ni las comunicaciones privadas de otras personas.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
wireshark --version
```

Primer ejercicio seguro

Captura solo tu propia interfaz de red de laboratorio mientras haces un 'ping' y una consulta DNS. Para rápido y aplica filtros de pantalla como 'icmp' y 'dns'.

Qué buscar

- ✓ Direcciones de origen y destino.
- ✓ Campos de protocolo y relaciones de solicitud/respuesta.
- ✓ Contenido cifrado frente a contenido no cifrado.

Errores comunes de principiantes

- ✓ Capturando en la interfaz equivocada.
- ✓ Dejar una captura demasiado larga.
- ✓ Compartiendo archivos de paquetes que contienen secretos.

Nivel de riesgo

Riesgo medio de privacidad. Las capturas de paquetes pueden contener credenciales, tokens y datos personales.

Recursos oficiales

[Wireshark en Kali](#)

[Documentación de Wireshark](#)

8.5 Edición Comunitaria de Burp Suite

PROXY DE PRUEBAS DE APLICACIONES WEB

Qué es y por qué importa

Burp intercepta y examina las solicitudes del navegador y las respuestas de las aplicaciones. Enseña cómo se comunican las aplicaciones web y soporta pruebas manuales cuidadosas.

Cuando usarlo

Probando un laboratorio web asignado. Entender cookies, cabeceras, formularios y solicitudes de API.

Cuando no usarlo

No interceptes el tráfico de otra persona. No utilicéis ataques automatizados contra aplicaciones no aprobadas.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
Burpsuite --ayuda
```

Primer ejercicio seguro

Configura un navegador de laboratorio para usar Burp, visita una aplicación de entrenamiento asignada e inspecciona una solicitud GET inofensiva en el historial de solicitudes HTTP.

Qué buscar

- ✓ Método, ruta, parámetros, encabezados y cookies.
- ✓ Estado de la respuesta y tipo de contenido.
- ✓ ¿Qué campos están controlados por el usuario?

Errores comunes de principiantes

- ✓ Instalando el certificado de la CA de Burp en el perfil principal del navegador.
- ✓ Mantener el proxy activado después del laboratorio.
- ✓ Marcar un resultado de escáner como probado.

Nivel de riesgo

Riesgo medio. Las solicitudes modificadas pueden actualizar datos o desencadenar acciones de la aplicación.

Recursos oficiales

[Suite de eructos en Kali](#)

[Academia de Seguridad Web PortSwigger](#)

8.6 Marco Metasploit

MARCO DE INVESTIGACIÓN Y VALIDACIÓN DE VULNERABILIDADES

Qué es y por qué importa

Metasploit proporciona módulos para investigación, validación, cargas útiles y postexplotación controlada. Ayuda a demostrar el impacto de las debilidades conocidas en un laboratorio.

Cuando usarlo

Validando una vulnerabilidad específica y confirmada en el laboratorio. Aprender cómo los módulos de explotación requieren opciones y contexto objetivo.

Cuando no usarlo

No "pruebes módulos" en servicios aleatorios. No utilice cargas útiles persistentes o destructivas fuera de un laboratorio diseñado específicamente para ello.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
MSFCONSOLE --version
```

Primer ejercicio seguro

Abre 'msfconsole', usa 'search' para investigar un módulo mencionado por un laboratorio jubilado o de Starting Point, y lee 'info' antes de establecer un objetivo. No lo lances hasta que el laboratorio lo solicite explícitamente.

Qué buscar

- ✓ Opciones requeridas.
- ✓ Objetivos apoyados.
- ✓ Referencias a los módulos y a los efectos secundarios.

Errores comunes de principiantes

- ✓ Seleccionar un módulo basándose únicamente en el nombre de un producto.
- ✓ Ignorar la arquitectura objetivo.
- ✓ Correr como root sin necesidad de hacerlo.

Nivel de riesgo

Alto riesgo. La explotación puede provocar que los servicios se colapsen, crear sesiones o alterar un objetivo.

Recursos oficiales

[Metasploit en Kali](#)

[Documentación de Metasploit](#)

8.7 Gobuster

DESCUBRIMIENTO DE CONTENIDO WEB Y NOMBRES

Qué es y por qué importa

Gobuster utiliza listas de palabras para descubrir directorios, archivos, nombres de dominio (DNS) o anfitriones virtuales. Encuentra contenido que puede existir pero que no está enlazado desde la web visible.

Cuando usarlo

Enumerando un sitio web asignado al laboratorio. Comparando las respuestas de los servidores con las rutas candidatas.

Cuando no usarlo

No utilices listas de palabras grandes contra sistemas no aprobados o frágiles. No interpretes todas las respuestas como contenido sensible.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

Version Gobuster

Primer ejercicio seguro

Ejecuta una breve enumeración de directorios contra una URL de laboratorio asignada, usando una lista de palabras modesta y un conteo conservador de hilos.

Qué buscar

- ✓ Códigos de estado.
- ✓ Tamaños de respuesta.
- ✓ Redirecciones y patrones de falsos positivos.

Errores comunes de principiantes

- ✓ Usar el modo equivocado.
- ✓ Ignorar las prórrogas.
- ✓ Sobrecargar el objetivo con demasiados hilos.

Nivel de riesgo

Riesgo de tráfico medio. La enumeración mediante una lista de palabras puede generar numerosas solicitudes.

Recursos oficiales

[Gobuster en Kali](#)

8.8 FFUF

FUZZER FLEXIBLE DE TELARAÑA

Qué es y por qué importa

FFUF coloca un marcador FUZZ en una petición y sustituye los valores de una lista de palabras. Soporta el descubrimiento de directorios, parámetros, cabeceras y hosts virtuales con filtrado flexible.

Cuando usarlo

Probar una ubicación específica de entrada en un laboratorio asignado. Filtrar las respuestas por código, palabras, líneas o tamaño.

Cuando no usarlo

No empieces con listas de palabras enormes ni con tasas altas. No confundas las solicitudes de cambio de estado sin entender sus consecuencias.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

ffuf -V

Primer ejercicio seguro

Utiliza una pequeña lista de palabras contra la ruta de un directorio de laboratorio y, primero, observa la respuesta por defecto ante un valor inexistente.

Qué buscar

- ✓ Patrones consistentes en el tamaño de la respuesta.
- ✓ Códigos de estado distintos.
- ✓ Si un hallazgo es reproducible en el navegador.

Errores comunes de principiantes:

- ✓ No filtrar respuestas comodín.
- ✓ Usando demasiados hilos.
- ✓ Corregir la parte incorrecta de una URL.

Nivel de riesgo

Riesgo de tráfico medio, potencialmente alto con tasas agresivas.

Recursos oficiales

[FFUF sobre Kali](#)

[Proyecto FFUF](#)

8.9 Nadie

ESCÁNER DE REVISIÓN DE SERVIDORES WEB

Qué es y por qué importa

Nikto revisa los servidores web en busca de archivos conocidos, firmas desactualizadas y problemas de configuración comunes. Ofrece una introducción rápida y fácil de entender a las comprobaciones automatizadas del servidor web.

Cuando usarlo

Revisión anticipada de un servidor de entrenamiento asignado. Generando elementos para verificación manual.

Cuando no usarlo

No trates la salida como un informe final de vulnerabilidad. No vayas en contra de la producción sin consideraciones aprobadas de calendario y tarifa.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

nobody -Versión

Primer ejercicio seguro

Ejecuta Nikto únicamente contra un servidor web de entrenamiento designado y guarda el informe resultante. Confirma manualmente un elemento informativo de bajo riesgo.

Qué buscar

- ✓ Cabeceras de servidores.
- ✓ Posibles archivos o problemas de configuración.
- ✓ Falsos positivos y firmas desactualizadas.

Errores comunes de principiantes

- ✓ Reportar cada elemento como crítico.
- ✓ Ignorar redirecciones o hosts virtuales.
- ✓ Ejecutarse sin permiso porque es "solo un escaneo".

Nivel de riesgo

Medio. Genera tráfico de escaneo reconocible y puede activar las defensas.

Recursos oficiales

[Nadie en Kali](#)

8.10 sqlmap

AUTOMATIZACIÓN DE PRUEBAS DE INYECCIÓN SQL

¿Qué es y por qué importa? SQLMAP ayuda a detectar y validar inyecciones SQL en los parámetros de los formularios web. Demuestra el grave impacto de las consultas a bases de datos inseguras cuando se realizan en un laboratorio diseñado específicamente para tal fin.

Cuando usarlo

Un laboratorio diseñado específicamente para la inyección SQL. Confirmando un parámetro sospechoso de inyección manual.

Cuando no usarlo

No pruebes formularios públicos arbitrarios. No volques datos solo porque la herramienta ofrece la opción.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
SQLMAP --versión
```

Primer ejercicio seguro

Usa sqlmap solo en una lección dedicada a inyección SQL y comienza con configuraciones orientadas a la detección. Para antes de la extracción de datos, a menos que el laboratorio lo exija específicamente.

Qué buscar

- ✓ Probé parámetros y técnicas de inyección.
- ✓ Confianza en las huellas dactilares de la base de datos.
- ✓ Solicitudes que produjeron el resultado.

Errores comunes de principiantes

- ✓ Usando el máximo riesgo y nivelación inmediata.
- ✓ Enviando solicitudes de cambio de estado.
- ✓ Recopilando datos innecesarios.

Nivel de riesgo

Alto. Puede generar numerosas solicitudes, modificar datos o recuperar registros sensibles.

Recursos [oficiales sqlmap](#)

[en el proyecto sqlmap](#)

[Kali](#)

8.11 OWASP ZAP

PROXY WEB Y ESCÁNER

Qué es y por qué importa

ZAP proporciona funciones de intercepción, rastreo, análisis pasivo y escaneo activo. Su flujo de trabajo gráfico es accesible para aprender pruebas web y distinguir entre acciones pasivas y activas.

Cuando usarlo

Revisión pasiva de tu propia solicitud de formación. Escaneo guiado en un laboratorio aislado.

Cuando no usarlo

No escanear activamente los sistemas sin aprobación explícita. No des por hecho que todas las alertas son explotables.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

versión de zaproxy

Primer ejercicio seguro

Haz un proxy a una sesión local de OWASP Juice Shop a través de ZAP y revisa las alertas pasivas antes de habilitar cualquier escaneo activo.

Qué buscar

- ✓ Confianza y evidencia de alerta.
- ✓ Diferencia entre chequeos pasivos y activos.
- ✓ URL y parámetro afectados.

Errores comunes de principiantes

Iniciar un escaneo activo por accidente. Reportar encabezados informativos como hallazgos graves.

Nivel de riesgo

De media a alta dependiendo del uso del escáner.

Recursos oficiales

[ZAP a Kali](#)

[Documentación de ZAP](#)

8.12 Hydra

PRUEBAS DE AUTENTICACIÓN EN LÍNEA

Qué es y por qué importa

Hydra prueba combinaciones de nombre de usuario y contraseña contra los servicios compatibles. Puede demostrar credenciales débiles y la ausencia de medidas de protección de la cuenta en un laboratorio controlado.

Cuando usarlo

Un laboratorio que enseñe explícitamente la auditoría de credenciales. Probando una pequeña lista de cuentas aprobadas con reglas de bloqueo conocidas.

Cuando no usarlo

Nunca pruebes cuentas reales sin autorización. No se ejecute cuando se desconozcan el bloqueo, los límites de velocidad o la estabilidad del servicio.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

Hydra -H

Primer ejercicio seguro

Usa solo una cuenta de laboratorio hecha a medida y una lista corta de palabras. Confirma el protocolo de autenticación esperado y el objetivo del laboratorio.

Qué buscar

- ✓ Indicación de credencial exitosa.
- ✓ Errores de conexión y falsos positivos.
- ✓ Comportamiento de límite de tasa o de bloqueo.

Errores comunes de principiantes

- ✓ Usar el módulo de servicio equivocado.
- ✓ Probando una lista grande inmediatamente.
- ✓ Provocando bloqueos de cuentas.

Nivel de riesgo

Alto. Puede bloquear cuentas, sobrecargar la autenticación y desencadenar respuesta a incidentes.

Recursos oficiales

[Hydra en Kali](#)

8.13 Juan el Destripador

AUDITORÍA OFFLINE DE HASH DE CONTRASEÑAS

Qué es y por qué importa

John prueba hashes de contraseñas contra contraseñas candidatas y reglas. La auditoría offline ayuda a demostrar la validez de la contraseña sin tener que volver a contactar con un servicio de inicio de sesión.

Cuando usarlo

Hashes proporcionados por un laboratorio de formación. Auditoría de hashes obtenidos mediante un proceso aprobado.

Cuando no usarlo

No utilices bases de datos de contraseñas robadas. No subas hashes a servicios públicos de cracking sin permiso.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
john --list=build-info
```

Primer ejercicio seguro

Crea hashes a partir de contraseñas ficticias en un laboratorio y usa una pequeña lista de palabras para observar por qué las contraseñas predecibles fallan.

Qué buscar

- ✓ Formato hash.
- ✓ Contraseña recuperada y tiempo necesario.
- ✓ ¿Qué patrones de contraseña eran débiles?

Errores comunes de principiantes

- ✓ No identificar el tipo de hash.
- ✓ Exponiendo contraseñas recuperadas.
- ✓ Asumir que lo no recuperado implica algo fuerte.

Nivel de riesgo

Riesgo medio de confidencialidad. Las credenciales recuperadas deben protegerse.

Recursos oficiales

[John sobre Kali](#)

8.14 Hashcat

AUDITORÍA DE HASH DE ALTO RENDIMIENTO

Qué es y por qué importa

Hashcat utiliza CPUs o GPUs y soporta numerosos formatos de hash y modos de ataque. Enseña cómo la longitud, la unicidad y la previsibilidad de la contraseña afectan la resistencia a ataques offline.

Cuando usarlo

Demostraciones controladas de la fuerza de la contraseña. Auditorías de hash autorizadas con hardware adecuado.

Cuando no usarlo

No utilices hashes procedentes de brechas sin autorización legal. Evita sobrecalentar o desestabilizar el hardware.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
hashcat --version
```

Primer ejercicio seguro

Usa un conjunto pequeño de hashes aleatorios y una lista corta de palabras. Controla la temperatura y compara los resultados con John.

Qué buscar

- ✓ Modo hash correcto.
- ✓ Candidatos recuperados.
- ✓ Limitaciones de rendimiento y hardware.

Errores comunes de principiantes

- ✓ Elegir el modo equivocado.
- ✓ Llevar una máscara poco realista indefinidamente.
- ✓ Ignorar los límites térmicos.

Nivel de riesgo

Riesgo de recursos y confidencialidad de medios a altos.

Recursos oficiales

[Hashcat en Kali](#)

[Wiki de Hashcat](#)

8.15 Aircrack-ng

KIT DE HERRAMIENTAS DE SEGURIDAD INALÁMBRICA

Qué es y por qué importa

Aircrack-ng soporta la captura inalámbrica, el análisis y las pruebas de seguridad aprobadas. Ayuda a explicar los canales Wi-Fi, los frames, la autenticación y por qué las evaluaciones inalámbricas requieren hardware especializado.

Cuando usarlo

Tu propio punto de acceso aislado y tus clientes. Una evaluación formal inalámbrica con alcance explícito.

Cuando no usarlo

No pruebes redes cercanas. No interrumpas a otros usuarios ni envíes tramas de desautenticación sin autorización explícita.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
aircrack-ng --ayuda
```

Primer ejercicio seguro

Empieza por comprobar si tu adaptador externo admite el modo monitor. Usa solo tu propio punto de acceso aislado para las pruebas.

Qué buscar

Modo adaptador, canal, BSSID, cliente y calidad de la captura.

Errores comunes de principiantes

- ✓ Suponiendo que el adaptador integrado admita el modo monitor.
- ✓ Seleccionar la red equivocada.
- ✓ Provocando interrupciones en el servicio.

Nivel de riesgo

Alto. Las acciones inalámbricas pueden afectar a personas más allá del objetivo previsto.

Recursos oficiales

[Crack-ng en Kali](#)

8.16 Bettercap

MARCO DE RECONOCIMIENTO DE RED Y MANIPULACIÓN DE TRÁFICO

Qué es y por qué importa

Bettercap soporta pruebas de descubrimiento, inspección y control de red. Demuestra cómo la confianza en la red local puede ser aprovechada indebidamente y por qué el cifrado y la segmentación son importantes.

Cuando usarlo

Una red aislada construida para el ejercicio. Observar a los anfitriones y los protocolos en tu propio laboratorio.

Cuando no usarlo

No realicéis interceptación en redes compartidas, públicas, escolares o laborales. No actives módulos de suplantación por casualidad.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
bettercap -version
```

Primer ejercicio seguro

Utiliza una red de laboratorio con solo hosts y comienza por el descubrimiento pasivo de los hosts. No permitas la interceptación ni el spoofing en el primer ejercicio.

Qué buscar

- ✓ Huéspedes descubiertos.
- ✓ Interfaces y alcance de red.
- ✓ ¿Qué módulos están activos?

Errores comunes de principiantes

Empezando por la interfaz equivocada. Habilitar módulos activos sin leer su efecto.

Nivel de riesgo

Alto. Un uso incorrecto puede provocar la interrupción del tráfico o de la conectividad.

Recursos oficiales

[Mejor tope para Kali](#)

[Documentación de Bettercap](#)

8.17 Respuesta

HERRAMIENTA DE EVALUACIÓN DE LA RESOLUCIÓN DE NOMBRES DE WINDOWS

Qué es y por qué importa

El respondedor evalúa debilidades en la resolución local de nombres de Windows y en el comportamiento de autenticación. Muestra cómo los protocolos de respaldo inseguros pueden comprometer el material de autenticación.

Cuando usarlo

Un laboratorio dedicado a Windows/Active Directory. Una evaluación interna autorizada con requisitos estrictos de manipulación.

Cuando no usarlo

Nunca funciones en una red corporativa, escolar, pública o doméstica con usuarios no involucrados. No recopiles ni violes credenciales de usuario reales fuera del alcance explícito.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
Responder -h
```

Primer ejercicio seguro

En un laboratorio de AD diseñado para tal fin, primero lee la configuración y aprende qué iniciarían los oyentes. Utiliza el modo de análisis antes de cualquier envenenamiento activo, cuando esté permitido.

Qué buscar

- ✓ Protocolos respetados.
- ✓ Sí, se enviaría una respuesta.
- ✓ ¿Qué artefactos sensibles podrían capturarse?

Errores comunes de principiantes

- ✓ Funcionando en la interfaz principal de red.
- ✓ Recopilando hashes de usuario no relacionados.
- ✓ Dejando la herramienta encendida.

Nivel de riesgo**Muy alto. Puede capturar material de autenticación e interferir con la resolución de nombres.****Recursos oficiales**[Respondedor en Kali](#)

8.18 NetExec

MARCO DE EVALUACIÓN DE WINDOWS Y ACTIVE DIRECTORY

Qué es y por qué importa

NetExec verifica SMB, WinRM, LDAP y otros servicios empresariales mediante credenciales autorizadas y la enumeración de servicios. Proporciona una forma consistente de evaluar grandes entornos de Windows y de comprender los permisos.

Cuando usarlo

Un laboratorio controlado de AD después de aprender sobre SMB, LDAP, Kerberos y el manejo de credenciales. Evaluación interna autorizada.

Cuando no usarlo

No pulverices contraseñas ni enumeres dominios reales sin aprobación. No utilices acciones privilegiadas antes de confirmar el alcance.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
NXC --version
```

Primer ejercicio seguro

En un laboratorio de AD, consulta un host asignado con credenciales conocidas y utiliza una opción de solo lectura. Anota exactamente qué permiso se necesitaba.

Qué buscar

- ✓ Resultado de autenticación.
- ✓ Información del host y del dominio.
- ✓ Módulos de solo lectura frente a módulos de modificación.

Errores comunes de principiantes

- ✓ Usar credenciales de producción en un comando de entrenamiento.
- ✓ Atacar accidentalmente toda una subred.
- ✓ Confundiendo autenticación con autorización.

Nivel de riesgo**Alto. Puede probar credenciales a gran escala e invocar acciones remotas.****Recursos oficiales**[Documentación de NetExec](#)

8.19 enum4linux-ng

ENUMERACIÓN SMB Y WINDOWS

¿Qué es y por qué importa? enum4linux-ng recopila información accesible de sistemas con SMB/Samba. Ayuda a los principiantes a organizar usuarios, grupos, compartidos, políticas e información de dominio.

Cuando usarlo

Después de que Nmap identifica SMB en un objetivo asignado. Un laboratorio controlado de Windows o Samba.

Cuando no usarlo

No enumeres sistemas fuera del alcance. No asumas que el acceso anónimo es inofensivo.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
enum4linux-ng -h
```

Primer ejercicio seguro

Ejecuta SMB contra un objetivo de laboratorio asignado y exporta los resultados a un archivo. Compara el resultado con las observaciones manuales de 'smbclient'.

Qué buscar

Compartidos, usuarios, grupos, políticas y nombres de dominio. Resultados de acceso denegado frente a anónimos.

Errores comunes de principiantes: ignorar entradas falsas o duplicadas. Copiar listas de usuarios sensibles en notas públicas.

Nivel de riesgo

Medio. La enumeración puede revelar detalles organizativos sensibles.

Recursos oficiales [enum4linux-ng sobre Kali](#)

8.20 Searchsploit

BÚSQUEDA LOCAL DE LA BASE DE DATOS DE EXPLOITS

Qué es y por qué importa

Searchsploit busca en un catálogo local de referencias públicas sobre explotación y pruebas de concepto. Conecta las versiones exactas de los productos con la investigación de seguridad manteniendo la búsqueda local.

Cuando usarlo

Investiga después de identificar un producto y una versión precisos. Leer código de exploits para entender los requisitos previos.

Cuando no usarlo

No ejecutes código de prueba de concepto sin previa revisión. No des por hecho que una búsqueda prueba la vulnerabilidad.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
searchsploit -h
```

Primer ejercicio seguro

Busca un producto usado en un laboratorio jubilado. Abre la referencia e identifica las versiones afectadas, los requisitos previos y si el código modifica el destino.

Qué buscar

- ✓ Gama de versiones.
- ✓ Tipo de exploit y fiabilidad.
- ✓ Privilegios requeridos y plataforma objetivo.

Errores comunes de principiantes

- ✓ Solo coincide con un nombre de producto amplio.
- ✓ Compilar código desconocido como root.
- ✓ Saltarme la revisión manual.

Nivel de riesgo

La investigación es de bajo riesgo; ejecutar código de exploit no revisado es un alto riesgo.

Recursos oficiales

[Searchsploit en Kali](#)

[Base de datos de exploits](#)

8.21 Autopsia

PLATAFORMA GRÁFICA DE FORENSE DIGITAL

Qué es y por qué importa

La autopsia ayuda a examinar imágenes de disco, archivos, metadatos, artefactos del navegador y líneas temporales. Ofrece a los principiantes una interfaz estructurada para el análisis forense.

Cuando usarlo

Muestra imágenes forenses. Investigaciones autorizadas de incidentes con copias forenses.

Cuando no usarlo

No abras la evidencia original de lectura y escritura. No expongas datos de casos ni archivos personales recuperados.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
Autopsia --ayuda
```

Primer ejercicio seguro

Crea un caso usando una imagen de entrenamiento disponible públicamente, calcula o verifica su hash y localiza metadatos básicos del sistema de archivos.

Qué buscar

- ✓ Fuente de pruebas y hash.
- ✓ Ajustes de zona horaria.
- ✓ Archivos recuperados y contexto de la línea temporal.

Errores comunes de principiantes

- ✓ Usando el dispositivo original como prueba de funcionamiento.
- ✓ Malinterpretar las marcas de tiempo.
- ✓ Exportar artefactos privados sin cuidado.

Nivel de riesgo

Riesgo medio de privacidad e integridad en las pruebas.

Recursos oficiales

[Autopsia de Kali](#)

[Documentación de la autopsia](#)

8.22 Maltés

VISUALIZACIÓN DE RELACIONES Y PLATAFORMA OSINT

Qué es y por qué importa

Maltego mapea las relaciones entre entidades públicas, infraestructuras y fuentes de información. Ayuda a los estudiantes a ver cómo pequeñas pistas públicas pueden combinarse en un cuadro más amplio.

Cuando usarlo

Investigar organizaciones ficticias o autorizadas. Mapeando tu propia exposición pública.

Cuando no usarlo

No acoses ni construyas perfiles invasivos de personas privadas. No trates una conexión visual como prueba.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
Maltego --Ayuda
```

Primer ejercicio seguro

Utiliza una empresa ficticia o tu propio dominio y un conjunto limitado de transformaciones públicas. Registra la calidad de la fuente para cada relación.

Qué buscar

- ✓ Fuente de cada entidad.
- ✓ Confianza y posibles explicaciones alternativas.
- ✓ Datos que no deberían publicarse.

Errores comunes de principiantes

Recopilando más información personal de la necesaria. Tratar la correlación como confirmación de identidad.

Nivel de riesgo

Privacidad y riesgo ético medios.

Recursos oficiales

[Maltego sobre Kali](#)

[Documentación de Maltego](#)

9. Fundamentos y herramientas de la Forense Digital

9.1 Fundamentos de la Forense Digital

Figura 6. Un flujo de trabajo básico de informática forense que protege la evidencia original.

La informática forense digital es la identificación, preservación, examen, análisis y reporte disciplinados de pruebas digitales. El objetivo no es simplemente encontrar archivos interesantes. El objetivo es producir conclusiones precisas y reproducibles, preservando la integridad y respetando la privacidad.

Obra a partir de copias

Cuando la evidencia importe, preserva el original, crea una imagen forense verificada, registra los hashes y realiza análisis sobre una copia funcional. Un alumno debe usar imágenes públicas de entrenamiento en lugar de dispositivos personales reales.

Conceptos fundamentales

- ✦ Cadena de custodia: un registro de quién manejó las pruebas, cuándo, por qué y cómo.
- ✦ Hash: una huella digital reproducible utilizada para verificar que la evidencia no ha cambiado.
- ✦ Bloqueador de escritura: controles de hardware o software destinados a impedir la modificación de los medios fuente.
- ✦ Cronología: una visión ordenada de los eventos derivados de sistemas de archivos, registros, aplicaciones y otros artefactos.
- ✦ Artefacto: un dato que puede respaldar una investigación, como el historial del navegador, el registro, los registros o los metadatos.
- ✦ Conclusión frente a conclusión: un artefacto observado no constituye automáticamente prueba de intención o identidad.

9.2 Kit de Detective

FORENSE DE SISTEMAS DE ARCHIVOS DE LÍNEA DE COMANDOS

Qué es y por qué importa

Proporciona herramientas para examinar imágenes de disco y estructuras de los sistemas de archivos. Útil para aprender análisis repetible y scriptable mediante interfaces gráficas.

Cuándo usarlo

- ✓ Respuesta autorizada a incidentes.
- ✓ Pruebas de formación pública.
- ✓ Tus propios datos de muestra preparados deliberadamente.

Cuando no usarlo

No analices el dispositivo ni la cuenta de otra persona sin autorización legal. No trabajes con evidencia original cuando la preservación importa.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
fls -V
```

Primer ejercicio seguro

Lista los archivos de una imagen pública de formación y compara las entradas asignadas y las eliminadas.

Qué buscar

- ✓ Registra la fuente y el hash.
- ✓ Observación separada de interpretación.
- ✓ Documenta la zona horaria, la versión de la herramienta y la ubicación de exportación.

Errores comunes de principiantes

- ✓ Seleccionar el dispositivo o la imagen incorrectos.
- ✓ Cambiando la evidencia.
- ✓ Exagerar lo que un artefacto demuestra.

Nivel de riesgo

Riesgo medio de integridad de la evidencia si se selecciona el dispositivo incorrecto.

Usar la IA de forma responsable con esta herramienta

La IA puede ayudar a resumir líneas de tiempo sanitizadas o explicar los formatos de archivo, pero no sube pruebas reales a un modelo público. Confirma todas las conclusiones del artefacto subyacente y la salida de la herramienta.

Recursos oficiales

[Kit de Detective](#)

9.3 Guymager

IMAGEN FORENSE

Qué es y por qué importa

Crea imágenes forenses y calcula hashes. Útil para aprender, adquirir, copiar, evidenciar y verificar.

Cuándo usarlo

- ✓ Respuesta autorizada a incidentes.
- ✓ Pruebas de formación pública.
- ✓ Tus propios datos de muestra preparados deliberadamente.

Cuando no usarlo

No analices el dispositivo ni la cuenta de otra persona sin autorización legal. No trabajes con evidencia original cuando la preservación importa.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

Guymager

Primer ejercicio seguro

Imagina un dispositivo USB desechable que contiene archivos ficticios, nunca un dispositivo con datos personales reales.

Qué buscar

- ✓ Registra la fuente y el hash.
- ✓ Observación separada de interpretación.
- ✓ Documenta la zona horaria, la versión de la herramienta y la ubicación de exportación.

Errores comunes de principiantes

- ✓ Seleccionar el dispositivo o la imagen incorrectos. Cambiando la evidencia.

- ✓ Exagerar lo que un artefacto demuestra.

Nivel de riesgo

Alto riesgo si el origen y el destino se confunden.

Usar la IA de forma responsable con esta herramienta

La IA puede ayudar a resumir líneas de tiempo sanitizadas o explicar los formatos de archivo, pero no sube pruebas reales a un modelo público. Confirma todas las conclusiones del artefacto subyacente y la salida de la herramienta.

Recursos oficiales

[Guymager sobre Kali](#)

9.4 ExifTool

EXAMEN DE METADATOS

Qué es y por qué importa

Lee y escribe metadatos en múltiples formatos de archivo. Útil para entender marcas de tiempo, información de cámaras, propiedades de documentos y metadatos ocultos.

Cuándo usarlo

- ✓ Respuesta autorizada a incidentes.
- ✓ Pruebas de formación pública.
- ✓ Tus propios datos de muestra preparados deliberadamente.

Cuando no usarlo

No analices el dispositivo ni la cuenta de otra persona sin autorización legal. No trabajes con evidencia original cuando la preservación importa.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
exiftool -ver
```

Primer ejercicio seguro

Ejecuta ExifTool en tus propias imágenes y documentos de muestra. Compara los tiempos del sistema de archivos con los metadatos embebidos.

Qué buscar

- ✓ Registra la fuente y el hash.
- ✓ Observación separada de interpretación.
- ✓ Documenta la zona horaria, la versión de la herramienta y la ubicación de exportación.

Errores comunes de principiantes

- ✓ Seleccionar el dispositivo o la imagen incorrectos.
- ✓ Cambiando la evidencia.
- ✓ Exagerar lo que un artefacto demuestra.

Nivel de riesgo

Bajo al leer ejemplares; Escribir metadatos puede alterar la evidencia.

Usar la IA de forma responsable con esta herramienta

La IA puede ayudar a resumir líneas de tiempo sanitizadas o explicar los formatos de archivo, pero no sube pruebas reales a un modelo público. Confirma todas las conclusiones del artefacto subyacente y de la salida de la herramienta.

Recursos oficiales

[ExifTool sobre Kali](#)

[ExifTool](#)

9.5 Pasarela de contenedores

ANÁLISIS DE DATOS Y FIRMWARE EMBEBIDOS

Qué es y por qué importa

Identifica firmas y objetos incrustados en archivos binarios. Útil para conceptos introductorios sobre firmware y el tallado de archivos.

Cuándo usarlo

- Respuesta autorizada a incidentes.
- Pruebas de formación pública.
- Tus propios datos de muestra preparados deliberadamente.

Cuando no usarlo

No analices el dispositivo ni la cuenta de otra persona sin autorización legal. No trabajes con evidencia original cuando la preservación importa.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

Caminata de la Caja de
Alimentos -- Ayuda

Primer ejercicio seguro

Analizar una imagen de firmware de muestra disponible públicamente e identificar firmas sin ejecutar automáticamente el contenido extraído.

Qué buscar

- ✓ Registra la fuente y el hash.
- ✓ Observación separada de interpretación.
- ✓ Documenta la zona horaria, la versión de la herramienta y la ubicación de exportación.

Errores comunes de principiantes

- ✓ Seleccionar el dispositivo o la imagen incorrectos.
- ✓ Cambiando la evidencia.
- ✓ Exagerar lo que un artefacto demuestra.

Nivel de riesgo

Medio. Los archivos extraídos pueden no ser confiables.

Usar la IA de forma responsable con esta herramienta

La IA puede ayudar a resumir líneas de tiempo sanitizadas o explicar los formatos de archivo, pero no sube pruebas reales a un modelo público. Confirma todas las conclusiones del artefacto subyacente y la salida de la herramienta.

Recursos oficiales

[Caminata de la basura en Kali](#)

9.6 Volatilidad 3

FORENSE DE LA MEMORIA

Qué es y por qué importa

Analiza imágenes de memoria compatibles para recuperar artefactos de proceso, de red y del sistema operativo. Útil para responder a incidentes y entender qué existía en la memoria en el momento de la captura.

Cuándo usarlo

- ✓ Respuesta autorizada a incidentes.
- ✓ Pruebas de formación pública.
- ✓ Tus propios datos de muestra preparados deliberadamente.

Cuando no usarlo

No analices el dispositivo ni la cuenta de otra persona sin autorización legal. No trabajes con evidencia original cuando la preservación importa.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
vol. -h
```

Primer ejercicio seguro

Utiliza una imagen pública de la memoria de Windows y haz una lista con la información básica de los procesos. Verifica los requisitos de los plugins y la compatibilidad de la imagen.

Qué buscar

- ✓ Registra la fuente y el hash.
- ✓ Observación separada de interpretación.
- ✓ Documenta la zona horaria, la versión de la herramienta y la ubicación de exportación.

Errores comunes de principiantes

- ✓ Seleccionar el dispositivo o la imagen incorrectos.
- ✓ Cambiando la evidencia.
- ✓ Exagerar lo que un artefacto demuestra.

Nivel de riesgo

Alto riesgo de privacidad; La memoria puede contener credenciales y datos privados.

Usar la IA de forma responsable con esta herramienta

La IA puede ayudar a resumir líneas de tiempo sanitizadas o explicar los formatos de archivo, pero no sube pruebas reales a un modelo público. Confirma todas las conclusiones del artefacto subyacente y la salida de la herramienta.

Recursos oficiales

[Documentación de Volatility 3](#)

9.7 Primero

TALLA DE LIMA

Qué es y por qué importa

Recupera contenido similar a archivos a partir de datos en bruto basándose en cabeceras y firmas. Útil para entender la recuperación cuando falta información de directorio.

Cuándo usarlo

- ✓ Respuesta autorizada a incidentes.
- ✓ Pruebas de formación pública.
- ✓ Tus propios datos de muestra preparados deliberadamente.

Cuando no usarlo

No analices el dispositivo ni la cuenta de otra persona sin autorización legal. No trabajes con evidencia original cuando la preservación importa.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

el primero -V

Primer ejercicio seguro

Crea una pequeña imagen de consulta pública en un directorio de salida dedicado y revisa los falsos positivos.

Qué buscar

- ✓ Registra la fuente y el hash.
- ✓ Observación separada de interpretación.
- ✓ Documenta la zona horaria, la versión de la herramienta y la ubicación de exportación.

Errores comunes de principiantes

- ✓ Seleccionar el dispositivo o la imagen incorrectos.
- ✓ Cambiando la evidencia.
- ✓ Exagerar lo que un artefacto demuestra.

Nivel de riesgo

Almacenamiento medio y riesgo para la privacidad.

Usar la IA de forma responsable con esta herramienta

La IA puede ayudar a resumir líneas de tiempo sanitizadas o explicar los formatos de archivo, pero no sube pruebas reales a un modelo público. Confirma todas las conclusiones del artefacto subyacente y la salida de la herramienta.

Recursos oficiales

[Principalmente sobre Kali](#)

9.8 bulk_extractor

EXTRACCIÓN DE CARACTERÍSTICAS

Qué es y por qué importa

Escanea imágenes en busca de características, como direcciones de correo electrónico, URLs y otros patrones, sin analizar todos los sistemas de archivos. Útil para el triaje y para entender por qué los indicadores extraídos requieren contexto.

Cuándo usarlo

- ✓ Respuesta autorizada a incidentes.
- ✓ Pruebas de formación pública.

- ✓ Tus propios datos de muestra preparados deliberadamente.

Cuando no usarlo

No analices el dispositivo ni la cuenta de otra persona sin autorización legal. No trabajes con evidencia original cuando la preservación importa.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
bulk_extractor -V
```

Primer ejercicio seguro

Compara con una imagen de práctica pública y examina los informes sin asumir que cada cadena pertenece a un usuario.

Qué buscar

- ✓ Registra la fuente y el hash.
- ✓ Observación separada de interpretación.
- ✓ Documenta la zona horaria, la versión de la herramienta y la ubicación de exportación.

Errores comunes de principiantes

- ✓ Seleccionar el dispositivo o la imagen incorrectos.
- ✓ Cambiando la evidencia.
- ✓ Exagerar lo que un artefacto demuestra.

Nivel de riesgo

Alto riesgo para la privacidad mediante pruebas reales.

Usar la IA de forma responsable con esta herramienta

La IA puede ayudar a resumir líneas de tiempo sanitizadas o explicar los formatos de archivo, pero no sube pruebas reales a un modelo público. Confirma todas las conclusiones del artefacto subyacente y la salida de la herramienta.

Recursos oficiales [bulk_extractor](#) [proyecto](#)

9.9 Plaso/log2timeline

GENERACIÓN DE LÍNEAS TEMPORALES

Qué es y por qué importa

Recopila marcas de tiempo y artefactos procedentes de múltiples fuentes para crear líneas temporales forenses. Útil para reconstruir secuencias de actividad.

Cuándo usarlo

- ✓ Respuesta autorizada a incidentes.
- ✓ Pruebas de formación pública.
- ✓ Tus propios datos de muestra preparados deliberadamente.

Cuando no usarlo

No analices el dispositivo ni la cuenta de otra persona sin autorización legal. No trabajes con evidencia original cuando la preservación importa.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
log2timeline.py --ayuda
```

Primer ejercicio seguro

Construye una línea de tiempo a partir de una pequeña imagen de entrenamiento y filtrala a un rango de tiempo muy limitado.

Qué buscar

- ✓ Registra la fuente y el hash.
- ✓ Observación separada de interpretación.
- ✓ Documenta la zona horaria, la versión de la herramienta y la ubicación de exportación.

Errores comunes de principiantes

- ✓ Seleccionar el dispositivo o la imagen incorrectos.
- ✓ Cambiando la evidencia.
- ✓ Exagerar lo que un artefacto demuestra.

Nivel de riesgo

Media; Suposiciones erróneas sobre la zona horaria pueden inducir a error el análisis.

Usar la IA de forma responsable con esta herramienta

La IA puede ayudar a resumir líneas de tiempo sanitizadas o explicar los formatos de archivo, pero no sube pruebas reales a un modelo público. Confirma todas las conclusiones del artefacto subyacente y la salida de la herramienta.

Recursos oficiales

[Documentación de Plaso](#)

9.10 HIJOS

CLASIFICACIÓN BASADA EN PATRONES

Qué es y por qué importa

Utiliza reglas para identificar archivos o hacer coincidir, en memoria, patrones definidos de bytes y de texto. Útil para el triaje de malware y la clasificación repetible cuando las reglas están redactadas cuidadosamente.

Cuándo usarlo

- ✓ Respuesta autorizada a incidentes.
- ✓ Pruebas de formación pública.
- ✓ Tus propios datos de muestra preparados deliberadamente.

Cuando no usarlo

No analices el dispositivo ni la cuenta de otra persona sin autorización legal. No trabajes con evidencia original cuando la preservación importa.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

```
Yara --version
```

Primer ejercicio seguro

Escribe una regla inofensiva que identifique un marcador de texto ficticio en un directorio de ejemplo.

Qué buscar

- ✓ Registra la fuente y el hash.
- ✓ Observación separada de interpretación.
- ✓ Documenta la zona horaria, la versión de la herramienta y la ubicación de exportación.

Errores comunes de principiantes

- ✓ Seleccionar el dispositivo o la imagen incorrectos.
- ✓ Cambiando la evidencia.
- ✓ Exagerar lo que un artefacto demuestra.

Nivel de riesgo

Medio. Las malas reglas generan falsos positivos; Las muestras no fiables siguen siendo peligrosas.

Usar la IA de forma responsable con esta herramienta

La IA puede ayudar a resumir líneas de tiempo sanitizadas o explicar los formatos de archivo, pero no sube pruebas reales a un modelo público. Confirma todas las conclusiones del artefacto subyacente y la salida de la herramienta.

Recursos oficiales

[Documentación de YARA](#)

9.11 Ghidra

SUITE DE INGENIERÍA INVERSA

Qué es y por qué importa

Desensambla y descompila el código ejecutable para su análisis. Útil para aprender a nivel avanzado sobre programas, malware y vulnerabilidades.

Cuándo usarlo

- ✓ Respuesta autorizada a incidentes.
- ✓ Pruebas de formación pública.
- ✓ Tus propios datos de muestra preparados deliberadamente.

Cuando no usarlo

No analices el dispositivo ni la cuenta de otra persona sin autorización legal. No trabajes con evidencia original cuando la preservación importa.

Punto de control de autorización

Utiliza esta herramienta solo en un sistema que poseas, en un laboratorio asignado específicamente a ti o en un sistema cubierto por una autorización escrita y clara. Ser públicamente accesible no implica ser comprobable públicamente.

Comprueba que esté disponible

guí aRun

Primer ejercicio seguro

Abre un programa compilado inofensivo de "hello world" e identifica las cadenas y las funciones. No empieces con malware en vivo.

Qué buscar

- ✓ Registra la fuente y el hash.
- ✓ Observación separada de interpretación.
- ✓ Documenta la zona horaria, la versión de la herramienta y la ubicación de exportación.

Errores comunes de principiantes

- ✓ Seleccionar el dispositivo o la imagen incorrectos.
- ✓ Cambiando la evidencia.
- ✓ Exagerar lo que un artefacto demuestra.

Nivel de riesgo

Alta al analizar muestras maliciosas; El aislamiento es esencial.

Usar la IA de forma responsable con esta herramienta

La IA puede ayudar a resumir líneas de tiempo sanitizadas o explicar los formatos de archivo, pero no sube pruebas reales a un modelo público. Confirma todas las conclusiones del artefacto subyacente y la salida de la herramienta.

Recursos oficiales

[Ghidra](#)

10. Informando de lo que aprendes

Informando de lo que aprendes

Un profesional de seguridad es juzgado no solo por lo que puede descubrir, sino también por la forma clara, precisa y responsable en que lo comunica. Empieza a informar en tu primer laboratorio.

10.1 Plantilla sencilla de encontrar

Campo	Qué escribir
Título	Una descripción clara del problema.
Alcance	El objetivo autorizado exacto.
Observación	Lo que viste directamente.
Evidencia	Comando relevante, marca de tiempo y salida sanitizada.
Riesgo	¿Qué podría pasar y bajo qué condiciones?
Recomendación	Una acción correctiva práctica.
Campo	Qué escribir
Limitaciones	Lo que no probaste ni pudiste confirmar.

10.2 Evita estos errores de reporte

1. Llamar a una versión de un número es una vulnerabilidad confirmada sin validación previa.
2. Copiar la salida bruta del escáner sin explicar su importancia.
3. Usar palabras dramáticas, como "catastrófico", sin respaldo.
4. Incluyendo contraseñas, tokens, banderas o datos personales en un informe público.
5. Ocultando incertidumbre. Un informe profesional distingue claramente entre los hechos confirmados, las inferencias razonables y las preguntas abiertas.

11. Tus primeros 30 días con Kali Linux

Tus primeros 30 días con Kali Linux

11.1 Semana 1 - Construir cimientos seguros

1. Lee la sección de ética.
2. Instala Kali en una máquina virtual.

3. Actualízalo y crea una instantánea.
4. Aprende sobre archivos, directorios, permisos, procesos y redes básicas.
5. Crea un cuaderno de laboratorio.

11.2 Semana 2 - Aprende a observar

1. Usa Nmap en un objetivo asignado por el laboratorio.
2. Captura tu propio tráfico con Wireshark.
3. Aprende DNS, TCP, HTTP y TLS a nivel introductorio.
4. Escribe un pequeño hallazgo.

11.3 Semana 3 - Inicio de la práctica web y HTB

1. Máquinas Starting Point completas para principiantes.
2. Aprende el historial HTTP de Burp y el uso básico de Gobuster o FFUF.
3. Usa IA solo para explicar la salida sanitizada y luego verifícala.
4. Revisa las normas de HTB.

11.4 Semana 4 - Conecta las habilidades

1. Completar un pequeño laboratorio desde el descubrimiento hasta el informe.
2. Usa una imagen de entrenamiento forense para aprender sobre el hashing y los metadatos.
3. Revisa qué acciones fueron de bajo impacto, intrusivas o prohibidas.
4. Elige el siguiente camino de aprendizaje: pruebas de penetración, respuesta a SOC/incidentes, forense, nube, GRC o seguridad de IA.

Cómo se ve el éxito después de 30 días

Puedes operar con seguridad una máquina virtual de Kali, identificar un objetivo autorizado, realizar un descubrimiento básico, explicar la diferencia entre observación y explotación, proteger los datos de laboratorio y redactar un informe sencillo basado en evidencias. No se espera que conozcas todas las herramientas.

12. Inglés para carreras tecnológicas

No se necesita un inglés perfecto para empezar una carrera tecnológica. Muchos profesionales excelentes utilizan el inglés como segunda o tercera lengua. Sin embargo, el inglés práctico abre el acceso a más documentación, formación, comunidades y empleos internacionales.

12.1 Dónde aparece el inglés

1. Palabras clave de programación y opciones de línea de comandos
2. Mensajes de error y resultados de solución de problemas
3. Documentación oficial y notas de publicación
4. Problemas con GitHub, pull requests y avisos de seguridad
5. Reuniones de equipo, tickets, informes y entrevistas
6. Artículos de investigación e informes iniciales sobre nuevas amenazas

12.2 Un objetivo realista

El objetivo no es sonar como un hablante nativo. El objetivo es leer instrucciones, entender un error, buscar una solución, explicar un problema, escribir una actualización clara y describir tu trabajo en una entrevista. El inglés técnico mejora con el uso diario.

Los principiantes deberían empezar por el idioma que mejor entienden y usar el inglés como una herramienta profesional adicional. No esperes un inglés perfecto antes de empezar en ciberseguridad o desarrollo de software.

12.3 Recursos gratuitos para aprender inglés disponibles en todo el mundo

La mayoría de estos recursos ofrecen lecciones gratuitas a su propio ritmo. Algunas organizaciones también ofrecen clases particulares opcionales o presenciales, así que lee la página de precios antes de inscribirte en cualquier curso de pago.

Recurso	Mejor uso	Enlace oficial
British Council LearnEnglish	Vídeos gratuitos, lectura, escucha, gramática, vocabulario y actividades basadas en niveles.	Recurso oficial - learnenglish.britishcouncil.org
Examen de nivel libre del British Council	Una comprobación aproximada de nivel inicial.	Recurso oficial - learnenglish.britishcouncil.org
USA Aprende	Cursos estructurados de inglés para adultos con registro gratuito y seguimiento de progreso.	Recurso oficial - usalearns.org
VOA Aprendiendo Inglés	Clases de inglés americano, noticias más lentas, audio, vocabulario y cursos para principiantes.	Recurso oficial - learningenglish.voanews.com
Cisco Skills para Todos	Aprendizaje gratuito de tecnología y ciberseguridad que también desarrolla el inglés técnico. Busca en el catálogo inglés para IT y Ethical Hacker.	Recurso oficial - skillsforall.com
OpenLearn	Cursos gratuitos de The Open University, incluyendo cursos cotidianos y de estudio de inglés.	Recurso oficial - open.edu
BBC Learning English	Vídeos gratuitos, pronunciación, gramática, vocabulario y lecciones en directo.	Recurso oficial - bbc.co.uk
Duolingo	Práctica diaria gratuita de vocabulario y gramática básica; Es mejor usarlo junto con otros recursos de expresión oral y escucha.	Recurso oficial - duolingo.com
EF SET	Exámenes gratuitos de nivel de inglés y un resultado compartible; una evaluación en lugar de un curso completo.	Recurso oficial - efset.org

12.4 Un sencillo plan semanal de inglés

1. Estudia en una clase estructurada tres veces por semana.
2. Escuchar diez minutos de inglés al día.
3. Escribe cinco palabras técnicas y usa cada una en una frase.
4. Mantén los mensajes de error en su idioma original al buscar soluciones.
5. Explica en voz alta un concepto de Kali o de IA en inglés sencillo.
6. Mide el progreso cada tres a seis meses en lugar de todos los días.

13. Trayectoria profesional y aprendizaje continuo

Camino	Enfoque
SOC y respuesta a incidentes	Monitorización, triaje, investigación, contención y comunicación.
Pruebas de penetración	Evaluación autorizada, validación, informes y orientación en remediación.

Forense digital	Preservación de pruebas, análisis de artefactos, cronologías y conclusiones defendibles.
Ingeniería de seguridad	Diseñar, configurar y operar controles de seguridad.
Seguridad en la nube	Identidad, protección de datos, configuración, registro y seguridad de cargas de trabajo.
GRC	Gobernanza, riesgo, cumplimiento, políticas, diseño de controles y comunicación empresarial.
Seguridad de la IA	Evaluación de modelos, inyección rápida, seguridad RAG, protección de datos y gobernanza de la IA.

Kali es un laboratorio útil, no una carrera completa. Los empleadores valoran las redes, los sistemas operativos, los scripts, la nube, la identidad, la comunicación, la documentación y el juicio ético. Ve desarrollando la profundidad poco a poco y crea un portafolio que contenga informes de laboratorio limpios en lugar de banderas copiadas o capturas de pantalla sin explicación.

1. Soy el propietario del destino o cuento con autorización explícita.
2. La dirección IP, el nombre de host, la cuenta y la ventana temporal están dentro del alcance.
3. Entiendo si la acción es pasiva, activa, intrusiva o modificadora.
4. Conozco la salida esperada y la condición de parada.
5. Estoy guardando la salida en la carpeta correcta del laboratorio.
6. No estoy exponiendo credenciales, archivos VPN, datos de clientes ni banderas.
7. Puedo explicar por qué es necesario este comando.

Patrón de carpeta de laboratorio

```
~/labs/<plataforma>/<nombre-laboratorio>/
├── notas/
├── escaneos/
├── pruebas/
└── informe/
```

Término	Significado para principiantes
Active Directory (AD)	Los servicios de directorio de Microsoft solían gestionar usuarios, ordenadores, permisos y políticas en muchas organizaciones.
Modelo de IA	Un sistema informático entrenado para reconocer patrones o generar salidas como texto, imágenes o predicciones.
Superficie de ataque	Los sistemas, servicios, aplicaciones, identidades, dispositivos y rutas que podrían ser objetivos.
Autenticación	El proceso de demostrar quién o qué eres, normalmente mediante una contraseña, un token o un factor biométrico.
Autorización	Las reglas que determinan lo que una persona o sistema autenticado puede hacer.
Ataque de fuerza bruta	Intentando repetidamente muchas posibles contraseñas o claves. Esto puede bloquear cuentas o interrumpir sistemas y requiere autorización explícita.
Cadena de custodia	Un registro documentado de quién recogió, manejó, transfirió y examinó las pruebas digitales.
Suma de comprobación	Un valor calculado que se utiliza para comprobar si un archivo descargado ha cambiado o se ha corrompido.

Término	Significado para principiantes
---------	--------------------------------

Interfaz de línea de comandos (CLI)	Una forma basada en texto para controlar un ordenador mediante la introducción de comandos.
Vulnerabilidades y exposiciones comunes (CVE)	Un identificador público asignado a una vulnerabilidad conocida de ciberseguridad.
Credencial	Información utilizada para demostrar la identidad, como un nombre de usuario, una contraseña, una clave API, un certificado o un token.
Evidencia digital	Datos que pueden ayudar a explicar un evento, incidente o actividad y deben manejarse con cuidado.
Enumeración	Recopilación de información detallada sobre sistemas, cuentas, particiones, servicios o aplicaciones tras el descubrimiento inicial.
Exploit	Código o técnica que utiliza una vulnerabilidad para provocar un resultado no deseado.
Falso positivo	Un resultado que parece identificar un problema, pero resulta incorrecto al validarlo.
Imagen forense	Una copia bit a bit de un soporte de almacenamiento, creada para su examen, mientras se conserva el original.
Hash	Una huella digital calculada utilizada para identificar datos, verificar la integridad o respaldar auditorías de contraseñas.
Presentador	Un ordenador, servidor, teléfono, máquina virtual u otro dispositivo conectado a una red.
Proxy HTTP	Una herramienta que se sitúa entre un navegador y una aplicación web para inspeccionar las solicitudes y respuestas.
Respuesta a incidentes	El proceso organizado para prepararse, detectar, investigar, contener y recuperarse de incidentes de seguridad.
Dirección IP	Una dirección numérica utilizada para identificar y comunicarse con un dispositivo en una red.
Fuga de la cárcel	Un intento de hacer que un sistema de IA ignore sus reglas o salvaguardas previstas.
Privilegio mínimo	Dando a los usuarios y sistemas solo el acceso mínimo necesario para realizar sus tareas.
Registro	Un registro de eventos generado por un sistema operativo, una aplicación, un dispositivo de red o una herramienta de seguridad.
Malware	Software diseñado para interrumpir, dañar, espiar o obtener acceso no autorizado a sistemas o datos.
Servicio de red	Un programa que escucha conexiones y ofrece funciones como acceso a la web, correo electrónico, intercambio de archivos o acceso remoto.
Inteligencia de código abierto (OSINT)	Información recopilada legalmente de fuentes públicas.
Paquete	Una pequeña unidad de datos transmitida a través de una red.
Carga útil	La acción o el código entregado tras explotar una vulnerabilidad.
Prueba de penetración	Una evaluación autorizada y con alcance que busca identificar y validar de forma segura las debilidades de seguridad.
Puerto	Un punto final lógico numerado utilizado por los servicios de red.
Escalada de privilegios	Obtener permisos más allá de los asignados al usuario o proceso actual.

Inyección rápida	Instrucciones introducidas en contenido de entrada o recuperado que intentan manipular un sistema de IA para que ignore sus reglas previstas.
RAG	Generación aumentada por recuperación: un método que suministra información recuperada a un modelo de lenguaje antes de responder.
Reconocimiento	El proceso inicial de recopilación de información sobre un objetivo autorizado.
Divulgación responsable	Informar de forma privada de una vulnerabilidad de seguridad a la organización afectada y permitir un tiempo razonable para la corrección.
Riesgo	La posibilidad de que una amenaza explote una debilidad y cause daño, considerada junto con la probabilidad y el impacto.
Alcance	Los límites aprobados de una actividad de seguridad, incluyendo objetivos, fechas, cuentas y técnicas permitidas.
Término	Significado para principiantes
Servicio	Un programa que ofrece una función de red o sistema.
Shell	Un entorno de comandos utilizado para interactuar con un sistema operativo.
Instantánea	Un estado guardado de una máquina virtual que puede restaurarse tras un error o un cambio fallido.
Ingeniería social	Manipular a la gente para que revele información o tome acciones inseguras.
Amenaza	Una persona, evento, acción o condición capaz de causar daño.
Ficha	Un valor utilizado para representar identidad, autorización o sesión. Los tokens deben protegerse como las contraseñas.
Máquina virtual (VM)	Un ordenador basado en software que funciona dentro de un ordenador anfitrión físico.
VPN	Una red privada virtual que crea una conexión cifrada con otra red o entorno de laboratorio.
Vulnerabilidad	Una debilidad que puede ser explotada o crear riesgos.
Lista de palabras	Un archivo que contiene palabras o posibles valores utilizados por herramientas autorizadas de descubrimiento o auditoría de contraseñas.
Bloqueador de escritura	Un control de hardware o software utilizado para reducir la posibilidad de modificar el soporte de evidencia original.
Vulnerabilidad de día cero	Una vulnerabilidad que se ha descubierto recientemente y que puede que aún no tenga una solución disponible.

Este manual prefiere fuentes primarias y oficiales. El comportamiento de las herramientas, los paquetes, las capturas de pantalla y las reglas de la plataforma pueden cambiar. Sigue los enlaces a continuación y verifica las instrucciones actuales antes de actuar. [Kali Linux](#)

[Atrapa a Kali](#)

[Documentación de Kali](#)

[Documentación de la herramienta Kali](#)

[Documentación de virtualización de Kali](#)

[Hackea la caja](#)

[Punto de partida de HTB](#)

[Academia HTB](#)

[HTB Empezando](#)

[OWASP](#)

[Ciberseguridad del NIST](#)

[MITRE ATT&CK](#)

[MITRE ATLAS](#)

[Licencia Creative Commons](#)

Este es un proyecto educativo vivo. Se anima a los lectores a informar sobre enlaces rotos, explicaciones poco claras, problemas gramaticales, de accesibilidad y errores técnicos. No envíes credenciales, señales, soluciones de ActiveMachine, información personal, datos de clientes ni reclamaciones de exploits no verificadas.

Estructura planificada del repositorio de GitHub

```
kali-learning-manual/  
├── README.md  
├── LICENCIA  
├── CODE_OF_CONDUCT.md  
├── CONTRIBUTING.md  
├── CHANGELOG.md  
├── docs/en/  
├── docs/es/  
├── Docs/PT-BR/  
├── guías compañeros/  
├── activos/  
└── referencias/
```

El enlace al repositorio público se añadirá a la siguiente revisión después de que se cree el repositorio. La edición original se mantendrá en inglés, con ediciones debidamente localizadas en español latinoamericano y portugués brasileño.

Sigue aprendiendo. Mantente curioso. Usa tus habilidades para proteger a las personas.

Todo profesional experimentado en ciberseguridad fue una vez principiante.

Primera Edición Pública - Inglés Maestro - julio 2026

Gratuito para compartir educativos no comerciales bajo CC BY-NC-SA 4.0